

NICE-PAKE: On the Security of KEM-Based PAKE Constructions without Ideal Ciphers

Nouri Alnahawi^{1,5,6}, Jacob Alperin-Sheriff², Daniel Apon³, Gareth T. Davies⁴,
and Alexander Wiesmaier^{1,5,6}

¹ Hochschule Darmstadt. {nouri.alnahawi,alexander.wiesmaier}@h-da.de

² Independent Researcher. jacobmas@gmail.com

³ The MITRE Corporation. crypto@mitre.org

⁴ NXP Semiconductors. gareththomas.davies@nxp.com

⁵ National Research Center for Applied Cybersecurity ATHENE.

⁶ European University of Technology, European Union.

Abstract. We present the **No IC Encryption (NICE)-PAKE**, a (semi)-generic symmetric Password Authenticated Key Exchange (PAKE) framework providing a quantum-safe alternative for the *Ideal Cipher* (IC), utilizing simpler cryptographic components for the authentication step. To give a formal proof, we introduce the notions of **A-Part Secrecy (A-SEC-CCA)**, **Splittable Collision Freeness (A-CFR-CCA)** and **Public Key Uniformity (SPLIT-PKU)** for splittable LWE KEMs. We show the relation of the former to the Non-uniform LWE and the Weak-Hint LWE assumptions, as well as its application to ring and module LWE. Finally, we show how to obtain a secure PAKE from our construction with concrete parameter choices for common lattice-based KEMs.

Keywords: Password Authenticated Key Exchange (PAKE) · Key Encapsulation Mechanism (KEM) · Post-Quantum Cryptography (PQC) · Learning with Errors (LWE) · Ideal Cipher Model (IC)

1 Introduction

Password Authenticated Key Exchange (PAKE) protocols establish a session key between communication parties over insecure channels utilizing an asymmetric key agreement scheme combined with password-based authentication. In the absence of static public keys or certificates, PAKEs provide an alternative using a low entropy *long-lived-key* (pre-shared secret or password) known only to the communicating parties. Among several methods to perform this task [1], the very first PAKE, Encrypted Key Exchange (EKE) [2], relies on the simple idea of (symmetrically) encrypting the initiator’s public key using the password. The encrypted public key can only be decrypted, and hence be correctly used, by a receiver who has the same password. Thus, using the same password serves as authentication for both sides of the key agreement. Still, many PAKEs rely on quantum-vulnerable hardness assumptions such as (C)DH [1], which has led to increased attention on generic PAKEs from PQC KEMs (cf. Sec. 1.4).

1.1 Motivation

Recently, several generic KEM-based PQC PAKEs were proposed in the literature [3,4,5,6,7,8,9,10,11], with a noticeable focus on lattice-based schemes from Module Learning with Errors (MLWE). Despite some differences, most works rely on the *Ideal Cipher* (IC) model in their formal security analysis. The IC models a random block cipher as being chosen uniformly from the set of all possible block ciphers [12] and allows for defining a deterministic behavior on such ciphers. IC-modeled block ciphers have significant drawbacks in PAKEs that affect confidence in generic constructions (cf. Sec. 2). The public key permutations obtained from an IC are required to be statistically close to uniform [13], i.e., all outputs yield possible valid public keys. However, ML-KEM does not satisfy this requirement, since its keys are only computationally indistinguishable from uniform [13]. Thus, encrypting an ML-KEM public key may yield an invalid IC output distinguishable from uniform, which leads to multiple password guesses in one PAKE session. Furthermore, it is non-trivial to instantiate an IC as a block cipher over a group domain [9] and there are still no known adaptations for the IC model to deal with quantum adversaries (cf. Sec. 2).

1.2 Main Contribution

We present the **No IC Encryption (NICE)**-PAKE protocol (Fig. 1), a round-optimal PQC PAKE from lattice assumptions without an IC. We realize public key authentication in the form of a bit-wise XOR, instead of symmetric encryption of the public key. Inspired by [9], our construction incorporates LWE KEMs with splittable public keys of the form $(\mathbf{A}, \mathbf{b} = \mathbf{A}\mathbf{s} + \mathbf{e})$, where the uniform samples $\mathbf{A}$ are deterministically obtained from a fixed-length bit string seed. As the seed is either appended or prepended to the plain text representation of the public key, we mask (hide) it using the PAKE password. Thus, we allow perfect secrecy schemes to be applied on random bit strings of fixed length without resorting to block ciphers. As a result, we represent a major step in understanding how secure PAKEs can be built from lattice-based KEMs.

Intuitive Security. Without knowledge of the correct password π , it is not possible to retrieve the seed ρ required for re-composing the initiator’s public key $pk_a = (\mathbf{A}, \mathbf{b}) : \mathbf{A} \leftarrow \rho$ to invoke encapsulation, since it internally requires both parts of the public key. Valid ciphertexts generated from a key $\mathbf{a}$ with a non-matching $\mathbf{A}$ -part cannot be decapsulated correctly. Thus, only with a password known by both parties is it possible to successfully execute the KEM to obtain the same KEM output key. Although the protocol only provides implicit mutual authentication, explicit authentication can be realized through adding a key confirmation round as a final step.

Novel KEM Properties from (M)LWE Assumptions. We introduce three new properties from LWE (similarly RLWE and MLWE) assumptions (Sec. 4)

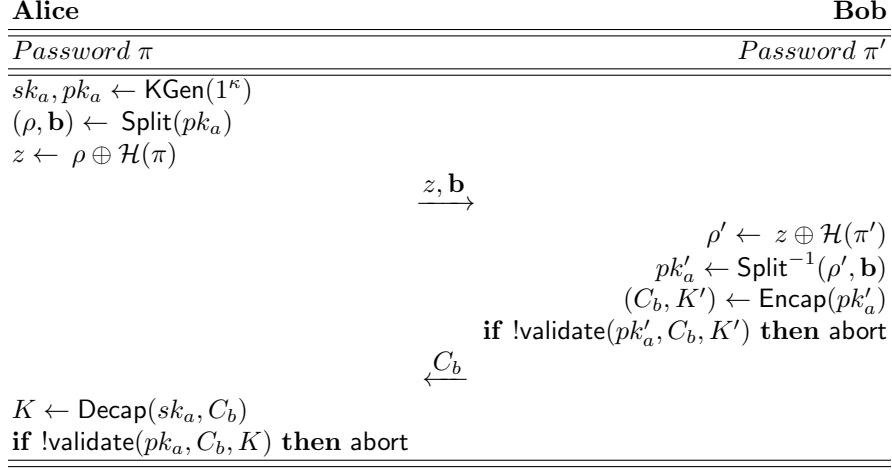


Fig. 1. The NICE-PAKE protocol utilizing the triple (*KGen*, *Encap* and *Decap*) of a KEM with splittable keys using a random seed ρ for the uniform sampling of the **A**-part of the public key.

and call them as **A**-Part Secrecy (**A**-SEC-CCA), Splittable Collision Freeness (**A**-CFR-CCA), and Public Key Uniformity (**SPLIT**-PKU) for KEMs with splittable public keys. Our proof for the newly introduced **A**-SEC-CCA property is based on additional *LWE* assumptions (cf. Sec. 3.3). These are the *Non-Uniform* and *Weak-Hint* *LWE* (*NLWE* and *whLWE*) assumptions, which allow for more flexible utilization of *LWE* schemes and variants thereof.

Security from Abstract KEM Properties. **A**-SEC-CCA and **A**-CFR-CCA (cf. Sec. 4) play a major role in our analysis by providing an equivalent to KEM properties used in recent PAKE proposals (cf. Sec. 1.4). However, ours are tailored for the indistinguishability and collision freeness w.r.t. the **A**-part embedded in a ciphertext, as opposed to the known anonymity and collision resistance. Especially, we show security even for an adversary that actively controls $\mathbf{b}$ or generates it maliciously, as **A** can still induce enough randomness to provide ciphertexts that do not decapsualte under non-matching **A**-parts. Note that the honest password usage is protected (information-theoretically) through the one-time XOR. Thus, an adversary cannot prove knowledge, nor gain partial information, about an honest choice of the **A**-part for non-matching passwords. This limits the number of online password guess to one per session, and thwarts offline dictionary attacks, except for a few cases (cf. Sec. 1.3).

NLWE and whLWE. Informally, *NLWE* enables sampling lattice points from a non-uniform distribution, and is used to switch the **A**-part in an *LWE* sample with negligible adversarial advantage (cf. Thm. 4). *whLWE* determines the adversarial advantage from crafting malicious *LWE* samples (i.e., public keys), as

it defines the leakage obtained from having hints on the encapsulator’s secret in a ciphertext in the form of linear combinations, embedded by the adversary in $\mathbf{b}$ (cf. Thm. 5). We show that A-SEC-CCA suffices for reducing PAKE security from anonymity provided that certain malicious public keys can be detected by the encapsulator. Similarly, A-CFR-CCA requires that certain malicious ciphertexts can be detected by the decapsulator. For concrete instantiations, we claim that this leads to a significant loss in bit security for schemes built from plain (unstructured lattices) LWE. Nevertheless, we present a way to regain a sufficient amount of the lost bits using a non-standard value for the Gaussian variance parameter (Sec. 6). We conclude that this method is not directly inter-changeable across other schemes from the Ring or Module LWE variants (e.g., NewHope and CRYSTALS-Kyber), and could lead to a complete break in security using the standard parameters (Sec. 6).

Comparison to Katana [14]. Dodis et al. [14] realized hybrid key exchange in the Signal protocol from *Katana*, a Kyber variant that they prove IND-CPA secure under the hardness assumptions of Hint-MLWE (hMLWE). The authors provide concrete parameters for a secure instantiation, which are roughly in-line with our approximation for the Gaussian distribution (cf. Sec. 6). Although we do not verify the correctness of our approximation, we assume similar heuristics to [14, Sec. 6.4] could apply to a fine-tuned NICE-PAKE. Hence, we suggest that with a secret of higher entropy for the encapsulator’s randomness, A-SEC-CCA is suitable to MLWE schemes with an acceptable loss in bit security resulting from reducing the dimension of the module lattice (cf. Sec. 6).

1.3 Challenges in the Formal Analysis of NICE-PAKE

Dealing with malicious public keys and ciphertexts Abstract KEM properties can only be applied for public keys and ciphertexts generated using the underlying KEM routines. Since adversaries are not bound to these routines, we need to deal with malicious values forwarded by a malicious Alice (i.e., $\mathbf{b}$ -part) or a malicious Bob (i.e., C_b). Here, we differentiate between two classes of adversarial messages: *malicious-valid* and *malicious-invalid*. The former are malicious yet valid KEM messages, where a mismatch in the $\mathbf{A}$ -part still yields indistinguishable decapsulations and produces different KEM output keys; and hence, A-SEC-CCA and A-CFR-CCA can be applied. The latter values are malformed, so that an adversary can bypass the mismatch in the $\mathbf{A}$ -part, and either trivially decapsulate (for a malicious Alice), or obtain the same KEM output key (for a malicious Bob). Although most KEMs incorporate the FO transform, which provides a validation method for the decapsulator, we also want to consider the potential of other KEMs in our construction. To overcome this challenge, we introduce a validity check in the protocol, to ensure that honest parties abort the execution when such *malicious-invalid* values are detected. We discuss the concrete functionality and instantiation possibilities of a ciphertext validity check (i.e., oracle) in Sec. 6.1.

Idealized Objects (ROM vs. QROM Programming). The Random Oracle Model (ROM) is considered a standard for modeling hash functions, which is also the case for PAKEs. Consequently, the presence of quantum adversaries requires modeling hash functions w.r.t. to quantum queries in superposition (QROM). We claim that our construction, although relying on one RO-modeled hash function, does not need to consider the QROM in our proof. This claim can be justified through observing one simple fact: *The space of all possible input values to $\mathcal{H}$ is an offline accessible and pre-defined password dictionary $\mathcal{D}$, the values in which are publicly known prior to PAKE session initiation.* That is, the hash function $\mathcal{H}$ is used to deterministically map a password π to a specific fixed-length output that matches the length of a fixed-length bit string (i.e., the seed ρ). It is thus obvious that an adversary can launch an offline dictionary attack (even without a quantum computer), and prepare a list of all hash outputs for all possible $\pi \in \mathcal{D}$. Therefore, they do not need to query $\mathcal{H}$ in superposition, as they can already obtain all possible outputs $\mathcal{H}(\pi_i)$. Ultimately, they can choose only one output $\mathcal{H}(\pi)$ to make a *committing* online password guess, and cannot change it adaptively in further interactions.

Password Extraction. Our proof is provided in the extended RoR (*Real-or-Random*) BPR (Bellare-Pointcheval-Rogaway) model [15] (Sec. 5). Conducting the formal analysis, we concluded that it is infeasible to extract password guesses from an adversary’s interaction with the protocol without a programmable IC (cf. Sec. 1.4). Although our construction and its informal security arguments may look similar to well known discrete-log based schemes, it is not possible to rely on interactive assumptions in the ROM to extract password guesses in this case. Considering the flow of a protocol execution, one may observe the following:

1. Extraction from a RO-modeled function $\mathcal{H}$ is not possible, as the implementing oracle only takes the password as input, and not a public key. Thus, an adversary can query $\mathcal{H}$ on multiple passwords π_i and later decide which one to use in masking their public key $\mathbf{A}$ -part seed ρ .
2. Extraction from an adversary’s ciphertext C_b is not possible, as the underlying KEM provides strong anonymity (ANO-CCA and A-SEC-CCA) and hence protects the public key and the $\mathbf{A}$ -part used in the encapsulation.

BPR vs UC Security. In order to achieve UC security with composability guarantees, a simulation-based proof is required, where the simulator needs to be able to extract adversarial password guesses. Since we do not extract guesses from adversaries’ messages, we cannot provide a sound simulation in UC. A method to overcome this obstacle can be found in adding an extra round at the end of the protocol, where honest parties (and adversaries) have to query a RO-modeled function to generate a key confirmation using their passwords. While this can be achieved via lazy-extraction in the relaxed UC model [16,17] in the ROM, involving an interactively queryable ROM means that it can also be adaptively queried by a quantum adversary. This requires adaptive re-programming in the QROM to realize a sound UC simulation [18,19,20]. Therefore, we deem such

improvements a work in progress. Finally, we note that the majority of PQC PAKE proposals in the literature are given in the BPR model [21].

1.4 Comparison to Recent Generic PAKE Constructions

Directly comparable Related work follow one design paradigm [21], namely that of (O)EKE [21], which enables generic usage of key agreement schemes in black-box manner. The high-level idea is to encrypt the public key and the ciphertext using the password in the EKE variant. Alternatively, in OEKE, the ciphertext is authenticated with a key confirmation tag only. We present an overview of the abstract security properties required in each PAKE construction in Tab. 1. These works can be further categorized into three groups: 1. *EKE with IC* [4,5,6,11]. 2. *EKE with half IC (HIC)* [7,9]. 3. *EKE without IC* [3,8,10].

Protocol	Session Key	Public Key	Ciphertext	Model(s)
POPF-EKE [3]	IND-CPA	PR	PR/ROB	ROM
(O)CAKE [4]	IND-CPA	Fuzziness	ANO-CPA	IC/ROM
HIC-EKE [7]	IND-CPA	UNI-PK	ANO-CCA	IC/ROM
Pan and Zeng (CAKE) [5]	IND-CPA	Fuzziness	ANO-PCA	IC-ROM
Alnahawi et al. (OCAKE) [6]	IND-CPA	PKU	ANO-PCA	IC-ROM
Januzelli et al. [8] (EKE)	IND-CCA*	PR	(S)PR-NM	ROM
Januzelli et al. [8] (OEKE)	IND-CCA*	PR	PR-NM/CFR	ROM
CHIC [9]	OW-CPA	UNI-PK	ANO-PCA	IC/ROM
NoIC-PAKE [10]	OW-CPA	UNI-PK	ANO-PCA	ROM
Hövelmanns et al. [11] (CAKE)	IND-CPA	PKU	ANO-PCA	(Q)IC/QROM
Hövelmanns et al. [11] (OCAKE)	IND-CPA	PKU	ANO-PCA	(Q)IC/QROM
This work (NICE-PAKE)	IND-CCA	SPLIT-PKU	A-SEC/A-CFR	ROM

* Since [8] requires (S)PR-NM, it is implied that the KEM also needs to provide IND-CCA.

Table 1. Required KEM Properties in Generic PQC PAKEs - Adapted from [21]

IC-EKE (CAKE). Beguinet et al. [4] presented one of the first generic PQC PAKEs ((O)CAKE) in UC. Follow-up works by Pan and Zeng [5] and Alnahawi et al. [6] offered further analysis for multi-user security in the BPR model. A common divisor among these works is that they all require KEMs satisfying public key uniformity (*Fuzziness* or PKU) and anonymity. Our proof requires roughly the same basic KEM properties in proof steps concerning honest sessions.

QROM Extraction and QIC. Hövelmanns et al. [11] showed how to lift the classical OCAKE proof given in [6] to quantum settings through incorporating the QROM for search and collision bounds, as well as online extraction of adversarial queries (including password guesses). The authors utilize the novel QROM techniques based on the compressed oracle function (CO), and its extractable variant (eCO). However, the proof still relies on a quantum IC equivalent, for which is compensated via a simulator **SIM** that may be used should the QIC be realized in the future. While our construction does not require extraction in the

QROM, a final key confirmation round, will indeed add a public oracle queryable by adversaries in superposition. As previously discussed, this step is currently a work in progress for NICE-PAKE. Nonetheless, since we eliminate the need for an IC, no direct comparison to SIM can be established in that sense.

Programming Anonymity Reductions. An interesting finding in [11] is showing the impossibility of a black-box reduction from anonymity without a programmable IC. This implies the need for programming the challenge public keys in the proof using techniques similar to the ones provided by an IC. Otherwise an adversary may be able to break anonymity through an offline dictionary attack upon receiving a ciphertext response to determine the most likely encapsulation public key. Although our construction relies on anonymity, we require the non-programmable variant only for passively observed sessions, where the public key is generated honestly. For an adversary controlling the key generation, we reduce to A-SEC-CCA, where the adversary is challenged to guess the used $\mathbf{A}$ -part. Here, an adversary does not need a decryption oracle, as they have the secret key to their chosen $\mathbf{b}$. The catch here is that they cannot determine an $\mathbf{A}$ -part embedded in a reduction to A-SEC-CCA, even if they were able to successfully decrypt the challenge ciphertext (discussed previously). Therefore, our reduction from A-SEC-CCA only needs to embed a random $\mathbf{A}$ and an expanded one from a possible seed obtained via unmasking based on the password dictionary $\mathcal{D}$ in its challenge (cf. Sec. 4). Hence, their success probability will remain upper bounded by random guessing over $\mathcal{D}$; plus the advantage they have against the hardness of whLWE w.r.t. parameters chosen for a concrete instantiation.

Splitting a KEM Public Key (HIC-EKE). Dos Santos et al. [7] presented a UC-secure PAKE under a relaxation of the IC called Half IC. Their EKE-KEM protocol utilizes a KEM and a modified 2-round Feistel construction (m2F). The m2F avoids using an IC over a group through defining an IC over a fixed-length bit string domain. Following that, Arriaga et al. [9] introduced the Compact HIC (CHIC) protocol, improving EKE-KEM [7] in computation and communication costs. The CHIC protocol utilizes the m2F construction in a white-box manner by using the public seed of a splittable KEM public key as the ephemeral randomness input used in the m2F construction of [7]. The authors in [9] also address the required KEM properties and define the notions of Passive One-Way Security (OW-CPA), Pseudo-Uniformity of Public Keys (UNI-PK), and Anonymity under Plaintext-Checkable Attacks (ANO-iPCA) for a chosen KEM. Our construction extends the concept of splittable KEMs to completely avoid the IC, and thus also extends the notion of UNI-PK to SPLIT-PKU via a straight forward reduction from (M)LWE.

POPF-EKE (NoIC-EKE). McQuoid et al. [3], Januzelli et al. [8], and Arriaga et al. [10] rely on Programmable-Once Public Functions (POPF) to realize EKE without an IC. These PAKEs may be instantiated from any PKE or KEM scheme that fulfill certain properties as shown in Tab. 1. Basically, the

POPF construction is a 2-round Feistel network (2f), which realizes as keyed randomized function [10]. The PAKE initiator’s public key is encrypted with a password-derived key by hashing the public key into an algebraic group (H2G). The 2f can also be queried in the reverse direction, and thus enables programming in UC. Whereas Arriaga et al. define the same KEM property requirements as in CHIC, McQuoid et al. and Januzelli et al. use different naming conventions for similar or identical properties (see Tab. 1).

Security Properties for (O)EKE and NICE-PAKE. Interestingly, and previously unaware of the following fact, our construction relies on the same properties required by [8] to realize a secure KEM-based OEKE. NICE-PAKE requires a KEM satisfying IND-CCA, SPLIT-PKU, ANO-CCA, A-SEC-CCA, and A-CFR-CCA. Considering that A-SEC-CCA and A-CFR-CCA serve as complementary properties for ANO-CCA and SCFR-CCA, NICE-PAKE is perfectly in-line with the definitions of [8]. According to the authors, a secure (O)EKE requires KEMs with a pseudo-random non-malleable (PR-NM) and collision-resistant second message (i.e., the ciphertext). Here, PR-NM is equivalent to strong pseudo-randomness as defined in [22], which can be achieved if the KEM simultaneously provides IND-CCA and ANO-CCA. Further, collision-resistance corresponds directly to SCFR-CCA, which we provide through A-CFR-CCA. Considering the performance overhead resulting from the 2f construction and the H2G operations within, NICE-PAKE clearly outperforms in term of efficiency. Still, we deem aspects related to modified scheme parameters a question for future work, as to how changing them may affect the overall performance.

1.5 Other Related Work

There already exist many PAKEs from PQC primitives in the literature, almost all of which are based on lattice LWE (e.g. [23,24,25,26,27,28]) and isogenies (e.g. [29,30,31]). However, apart from the previously discussed OCAKE proof [11], the only PQC PAKE with a complete security analysis in the QROM was given in 2024 by Lyu et al. [32]. The authors proposed the first PAKE protocol from isogeny assumptions in the Universal Composability (UC) framework and the Random Oracle Model (ROM), as well as two PAKE protocols from lattice LWE and the group-action decisional Diffie-Hellman (GA-DDH) in the QROM. Their presented construction is based on lossy public key encryption (LPKE) and is extended to security in the QROM by replacing the basic LPKE with an extractable LPKE (eLPKE). Moreover, the authors apply a Fujisaki-Okamoto (FO) transform to elevate the security of the chosen LPKE from IND-CPA to IND-CCA. Nevertheless, a comparison with the aforementioned works is infeasible, as they utilize PQC asymmetric primitives directly and build upon different PAKE design paradigms [21], i.e., they do not utilize PQC KEMs generically.

2 Shortcomings of the IC Model in PAKE Proofs

The ideal cipher model was formalized in PAKE settings in the BPR model [15]. It has been widely used in protocols instantiated with block ciphers (cf. Sec. 1.4). Thus, an IC serves modeling block ciphers (e.g., AES) as idealized objects similar to hash functions in the ROM with some exceptions [12]. Its advantage is defining the behavior of a cipher, where each encryption maps to an independently random permutation that belongs to the same set of possible inputs.

Definition 1 (Ideal Cipher). *IC is an invertible permutation function $\mathcal{C} : \{0, 1\}^\kappa \times \{0, 1\}^n \rightarrow \{0, 1\}^n$, where each key $k \in \{0, 1\}^\kappa$ defines a unique and independent random permutation $\mathcal{C}_k = \mathcal{C}(k, \cdot)$ on $\{0, 1\}^n$.*

Similar to a Random Oracle (RO), an IC provides oracle access for forward queries on the function $\mathcal{C}$, where an input of a pre-defined length is deterministically mapped to an output of the same length through a random permutation. However, the main difference here is that an IC also provides access for backward queries on $\mathcal{C}^{-1}$. Thus, it answers queries to both encryption and decryption and models invertible random permutations through an interface accessible in a protocol execution. Queries and responses to and from the IC oracle are modeled via lazy sampling and can be recorded in a list, which can then be used in steps of a protocol analysis to determine further action. This behavior is crucial in formulating sound proofs for three main reasons: 1. Keeping a record of both honestly and maliciously generated public values, ciphertexts, and secrets, 2. replacing values generated in a simulation with random values generated by a challenger, and 3. performing consistency checks across proof steps.

Quantum Ideal Cipher. Some works in the literature [33,34,35,36,37,38,39,40,41] address the notion of the *Quantum* IC model focusing on one-way functions and non-invertible permutations. However, it is not yet shown how to obtain the lazy sampling technique required for programming in PAKE proofs. The work by Unruh [40] models keyed invertible permutations similar to compressed function oracles (CFO) [42] by introducing compressed permutation oracles (CPO). The work by Majenz et al. [41] introduces permutation superposition oracles as a generalization of CFOs and shows the possibility of their usage in quantum queries on permutations and their inverses. Nevertheless, relying on a quantum equivalent of the IC model is not yet an option [11].

IC Issues in PAKEs. Narrowing down the issue at hand, and ignoring the QIC for a moment, using the IC for public key authentication in a PAKE models random permutations as values in the set of all possible public keys, such that $IC : \mathcal{K}_\pi \times \mathcal{PK} \rightarrow \mathcal{PK}$. This behavior ensures that decryption always yields a valid (i.e., possibly honestly generated) public key, regardless of the correctness of the password used for encryption or decryption. Further, the usage of IC in PAKEs ensures well-formed public keys, with the consequence that adversaries cannot use malicious keys to attack the security of the underlying asymmetric scheme.

This results in problems when instantiating an IC with real-world ciphers (such as AES) to encrypt structured keys (such as MLWE-based) as follows: 1. Encrypting (structured) keys under one key and decrypting them under another key may very well result in values that do not exist in the key space (i.e., invalid keys). 2. Malicious (non-well-formed) keys may very well be used by adversaries to break the underlying scheme.

Practical Example. We devise a simple PAKE construction (Fig. 2), which resembles EKE or CAKE, but with no IC involved for that matter. In the authentication step, one would simply map the password using a XOF to a fixed length bit string and then XOR the output with the public key. At first glance, such constructions seem very attractive and promise a smooth security proof relying solely on well-studied KEM properties (e.g., IND-CCA and ANO-CPA). However, not relying on IC properties (e.g., bijection and record keeping) quickly reveals that this is at least questionable.

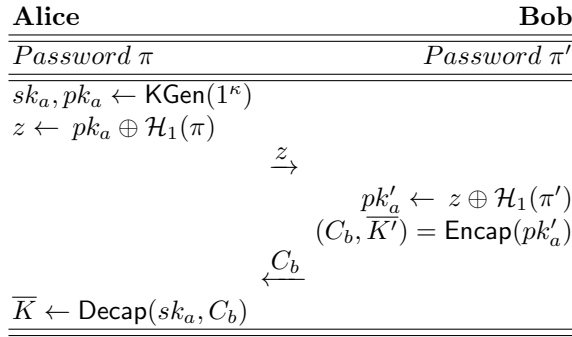


Fig. 2. Simple NICE-PAKE

First, we consider a malicious *Bob* who receives a masked pk as z as in Fig. 2. *Bob* may guess a password π' and observe the result of unmasking z . With probability bounded by the password dictionary size, it is likely that *Bob* guessed wrong. Assuming that not all z_i map to a valid pk_i under all π_i , he may observe an invalid pk' , which may be detectable, e.g., by checking the (wrong) structure. Then, *Bob* can exclude this one guess from an offline dictionary and take another guess in the same active session, and thus instantly break the PAKE security. In the specific case of Kyber, the KEM.KGen algorithm generates a public key that mathematically resembles a vector of polynomials (i.e., the **b**-part of the public key). Each polynomial has coefficients with values in $\mathbb{Z}_q$ where $q = 3329$ and is stored as 16-bit integer. This vector representation of the public key is then serialized into a byte array that maps two coefficients to three 8-bit integers. Unmasking the **b**-part may however yield a byte array that does not follow this structure, and thus to a polynomial with coefficients outside the range defined by the scheme parameters, which in turn leads to invalid public keys and thus enables detecting wrong password guesses. Considering FrodoKEM, this is

not the case, as its public keys are (close to) indistinguishable from random bit strings and do not yield a detectable mathematical structure.

Now, we consider a malicious *Alice* and a KEM where all z_i map to valid pk_i under all π_i . Note that a malicious *Alice* is neither restricted to honestly use KEM.KGen , nor to honestly calculate z . Thus, she may not necessarily be bounded by the security properties of the KEM that rely on honest key generation. Then, she could generate one or many malicious (non-well-formed) key pairs pk_i, sk_i and/or one or many malicious z_i and other data she may use to extract information from C_i . Note that these real-world problems vanish when modeling the key authentication using IC. An approach to prevent both attacks without an IC is restricting the PAKE to KEMs with splittable keys of the form $(\mathbf{A}, \mathbf{b} = \mathbf{A}\mathbf{s} + \mathbf{e})$ and enforcing an undetectable mismatch between $\mathbf{A}$ and $\mathbf{b}$ under wrong guesses of π for malicious Bob, and yielding an unusable C_b for malicious Alice. In the following, we investigate how this mismatch can be achieved.

3 Preliminaries

3.1 Notation

The security parameter is denoted by $\kappa \in \mathbb{N}$, and 1^κ is its unary representation. $a \leftarrow \text{Alg}(b)$ denotes running (potentially randomized) algorithm Alg on input b (with fresh random coins). We denote value assignment with $a \leftarrow (b, c)$. Choosing values at random (uniformly, or otherwise if it is clear from context) from a set $\mathcal{S}$ is denoted by $a \leftarrow \$ \mathcal{S}$. We use the notation $\text{Adv}_{\mathcal{A}, \Pi}^{\text{PROP}}(1^\kappa)$ to represent adversary $\mathcal{A}$'s advantage in playing the security experiment $\text{Exp}_{\mathcal{A}, \Pi}^{\text{PROP}}(1^\kappa)$ for security property PROP with primitive/protocol Π . To ease exposition we will often omit the security parameter from this experiment representation. For bit-guessing security experiments we follow convention and define two separate experiments parameterized by the choice bit, and define

$$\begin{aligned} \text{Adv}_{\mathcal{A}, \Pi}^{\text{PROP.BIT}}(1^\kappa) &= |\Pr[\text{Exp}_{\mathcal{A}, \Pi}^{\text{PROP.BIT}^0}(1^\kappa) = 1] \\ &\quad - \Pr[\text{Exp}_{\mathcal{A}, \Pi}^{\text{PROP.BIT}^1}(1^\kappa) = 1]| \end{aligned}$$

For experiments where the adversary tries to find collisions or in some way outputs something that is not a bit, we define in the usual way

$$\text{Adv}_{\mathcal{A}, \Pi}^{\text{PROP.FIND}}(1^\kappa) = \Pr[\text{Exp}_{\mathcal{A}, \Pi}^{\text{PROP.FIND}}(1^\kappa) = 1]$$

3.2 The Random Oracle Model

A random oracle [43] (RO) is an ideal primitive that models a random hash function that responds to each query to a given input value $m \in M$ with a random value $h = \mathcal{H}(m)$. Additionally, a RO keeps a record of all placed queries and responds with the same value for a previously queried input.

Definition 2 (Random Oracle). *RO is a function f that maps elements over the function space $\{0, 1\}^* \rightarrow \{0, 1\}^{\text{poly}(\lambda)}$, where:*

if $f(x) \neq \perp$ return $f(x)$ else return $y \leftarrow \$ \{0, 1\}^{\text{poly}(\lambda)}$

3.3 Lattice Assumptions: NLWE and whLWE

To obtain the new KEM security properties mentioned in Sec. 1.2 and formally defined in Sec. 4.2, we make use of the Non-Uniform LWE and Weak-Hint LWE assumptions formalized in the following. Essentially, we rely on NLWE to show that a ciphertext produced by an LWE encryption scheme can be viewed as an LWE sample from a certain distribution. Analogously, we rely on eLWE and whLWE to determine the amount of leakage on LWE secrets in the presence of so called “hints.” As these hints provide some random linear combinations of the secrets, they corresponds to possibly maliciously generated LWE samples in our context. We refer the reader to App. B for more details on LWE and its variants, App. C.1 for Extended LWE (eLWE) and to App. C.2 and C.3 for more details on NMLWE and eMLWE respectively.

Non-uniform Learning with Errors (NLWE). Boneh et al. [44] introduced a variant of the learning with errors (LWE) problem in which the columns of $\mathbf{A}$ (i.e. the LWE sample points) are sampled from a *non-uniform* distribution η over $\mathbb{Z}_q^n$ called the *Non-Uniform Learning with Errors* (NLWE) problem, and showed that for suitable parameters, it is as hard as the basic LWE problem. In what follows, let k denote the dimension of the NLWE problem and let n denote the dimension of the LWE problem. Also, write η^m to denote m independent samples from the distribution η .

Definition 3 (Non-uniform Learning with Errors). *For an integer $q = q(k) \geq 2$, a noise distribution $\chi = \chi(k)$ over $\mathbb{Z}_q$, and a distribution η over $\mathbb{Z}_q^k$, the $\text{NLWE}_{\mathbb{Z}_q, k, \chi, \eta}$ problem is to distinguish between two distributions:*

$$(\mathbf{A}, \mathbf{A}^T \mathbf{s} + \mathbf{e}) \text{ and } (\mathbf{A}, \mathbf{u})$$

where $m = \text{poly}(k)$, $\mathbf{A} \leftarrow \eta^m : \mathbf{A} \in \mathbb{Z}_q^{k \times m}$, $\mathbf{s} \leftarrow \mathbb{Z}_q^k$, $\mathbf{e} \leftarrow \chi^m$, and $\mathbf{u} \leftarrow \mathbb{Z}_q^m$.

Generally speaking, Boneh et al. [44] showed that, for any Probabilistic Polynomial Time (PPT) adversary, NLWE is as hard as LWE for any distribution η that is *coset samplable* defined as follows.

Definition 4 (Coset Samplable Distributions [44]). *For integers $q = q(k)$ and $n = n(k)$ we say that a distribution $\eta = \eta(k)$ over $\mathbb{Z}_q^k$ is n -coset samplable if there are two PPT algorithms (MatrixGen, SamplePre) such that:*

- MatrixGen($1^k, n, q$) outputs a matrix $\mathbf{M} \in \mathbb{Z}_q^{n \times k}$ and auxiliary data $\mathbf{T}$.
- SamplePre($\mathbf{z} \in \mathbb{Z}_q^n, \mathbf{T}$) outputs a $\mathbf{y} \in \mathbb{Z}_q^k$ satisfying $\mathbf{M}\mathbf{y} = \mathbf{z}$.

Moreover, if $\mathbf{z}$ is distributed *uniformly* in $\mathbb{Z}_q^n$, then the output of $\text{SamplePre}(\mathbf{z}, \mathbf{T})$ is distributed statistically close to η . That is, we have the following theorem: $\text{NLWE}_{\mathbb{Z}_q, k, \chi, \eta}$ is as hard as $\text{LWE}_{\mathbb{Z}_q, n, \chi}$ for any n -coset samplable distribution η .

Theorem 1 ([44]). *Let $\eta = \eta(k)$ be an n -coset samplable distribution. Suppose there is a PPT algorithm $\mathcal{A}$ that decides $\text{NLWE}_{\mathbb{Z}_q, k, \chi, \eta}$ with advantage $\varepsilon = \varepsilon(k)$. Then, there is a PPT algorithm $\mathcal{B}$ that decides $\text{LWE}_{\mathbb{Z}_q, n, \chi}$ with the same advantage $\varepsilon = \varepsilon(k)$.*

Following [44, Remark 4.4], we especially point out that the above holds even when $\mathbf{s}$ is distributed according to the error distribution rather than uniform.

Weak-Hint Learning with Errors (whLWE). Cheon et al. [45] (resp. Lee et al. [46]) defined Hint LWE (hLWE) and Weak-Hint LWE (whLWE) – with Liu et al. [47] providing a valuable discretization step in a recent preprint – as a potential enhancement of eLWE-type leakage-security properties, based on the following statistical insight about conditional Gaussian distributions:

Lemma 1 ([46], Lemma 4.8). *Let D_s denote a continuous Gaussian distribution with variance s . Let $D_{c,s}$ denote a continuous Gaussian distribution with center c and variance s . Then, for real numbers $\sigma_1, \sigma_2 > 0$, let e and f be random variables distributed as the Gaussian distributions D_{σ_1} and D_{σ_2} , respectively. Let $\sigma = \sqrt{\sigma_1^2 + \sigma_2^2}$, then the tuple $(e + f, e|(e + f))$ is distributed as the joint conditional Gaussian distribution $(D_\sigma, D_{L\sigma_1^2/\sigma^2, \sigma_1\sigma_2/\sigma})$ with L denoting $e + f$.*

We define the Weak-Hint LWE (whLWE) problem following [45,46]:

Definition 5 (Weak-Hint LWE). *Let n, q , and k be positive integers, $\sigma_1, \sigma_2 > 0$ be real numbers, $\mathbf{z}$ be a vector in Domain (with Domain arbitrary – but looking forward, we will choose $\text{Domain} := \mathbb{Z}_q^k$) and S be a matrix in $\mathbb{Z}_q^{n \times k}$. The Weak-Hint LWE distribution, denoted $A_{n,q,\sigma_1,\sigma_2,k}^{\text{whLWE}}(\mathbf{z}, S)$ is the distribution of $(\mathbf{a}, S^T \mathbf{a} + \mathbf{e}, \langle \mathbf{z}, \mathbf{e} \rangle + f) \in \mathbb{Z}_q^n \times \mathbb{R}_q^k \times \mathbb{R}_q$, where $\mathbf{a} \leftarrow \mathbb{Z}_q^n$, $\mathbf{e} \leftarrow D_{\sigma_q}^k$, and $f \leftarrow D_{\sigma_2}$, and where D is the secret distribution. Then the Weak-Hint LWE problem $\text{whLWE}_{n,q,\sigma_1,\sigma_2}^k(D)$ is to distinguish, given arbitrarily many independent samples $\mathbf{z} \leftarrow \text{Domain}$ chosen by an adversary, between $A_{n,q,\sigma_1,\sigma_2,k}^{\text{whLWE}}(\mathbf{z}, S)$ for a fixed $S \leftarrow D$ and the distribution of $(\mathbf{a}, \mathbf{u}, \langle \mathbf{z}, \mathbf{e} \rangle + f)$ where $\mathbf{u} \leftarrow \mathbb{R}_q$.*

Using Lemma 1, Cheon et al. [45,46] are able to show the following security theorem, which we will leverage in what follows.

Theorem 2. *Let n, q, k be positive integers. Let $\sigma_1, \sigma'_1, \sigma'_2$ be positive real numbers that satisfy $\sigma_1 = \sigma'_1 \sigma'_2 / \sqrt{(\sigma'_1)^2 + (\sigma'_2)^2}$. Finally, let D be a distribution over $\mathbb{Z}_q^{n \times k}$. Then there exists a polynomial-time reduction from $\text{LWE}_{n,q,\sigma_1}^k(D)$ to $\text{whLWE}_{n,q,\sigma'_1 \sqrt{k} \sigma'_2}^k(D)$, which exactly preserves the adversary's advantage.*

3.4 Key Encapsulation Mechanism (KEM)

Generally speaking, a KEM allows a key agreement initiator (encapsulator) to generate and share a symmetric key via a ciphertext to the receiver (decapsulator). It can be viewed as a special type of a public key encryption (PKE) algorithm [48], where the PKE is used to encrypt and decrypt a payload message, which is then used to derive said shared key. We shall first refer to generic (black-box) KEMs, and then narrow down our KEM definition to an important subset that satisfies specific properties, to which our results apply. Ultimately, we aim at a definition encompassing implicitly rejecting KEMs that utilize an internal PKE from lattice LWE primitives (also RLWE and MLWE variants) with splittable public keys, such as FrodoKem and CRYSTALS-Kyber.

KEM Syntax. In line with the work by Cremers et al. [48], we adopt a modified KEM API definition that allows us to explicitly use a public key as input to the decapsulation routine. By doing so, we can easily state whether the same public key was used in both encapsulation and decapsulation.

Definition 6 (Key Encapsulation Mechanism (KEM)). *KEM is a triple $(\text{KGen}, \text{Encap}, \text{Decap})$:*

- $\text{KGen}(1^\kappa) \rightarrow (pk, sk)$: *On input security parameter κ return key pair (pk, sk) (probabilistic algorithm), s.t. $pk \in \mathcal{PK}$, the public key space for KEM.*
- $\text{Encap}(pk) \rightarrow (C, K)$: *On input pk return ciphertext $C \in \mathcal{C}$ and key $K \in \mathcal{K}$ (probabilistic algorithm).*
- $\text{Decap}(sk, pk, c) \rightarrow K$: *On input sk , pk and ciphertext C : return key K*

where $\mathcal{C}$ is the ciphertext space and $\mathcal{K}$ is the session key space.

Correctness of KEM The correctness of a KEM means that the decapsulation algorithm KEM.Decap recovers the same shared key K produced by the encapsulation algorithm KEM.Encap for a public key generated by the key generation algorithm KEM.KGen . That is, however, except for a small probability over the space of key generation and encapsulation.

Definition 7 (KEM Correctness). *For every key pair $(pk, sk) \leftarrow \text{KGen}(1^\kappa)$ and every respective encapsulation $(C, K) \leftarrow \text{Encap}(pk)$, KEM is $(1 - \delta)$ correct if:*

$$\Pr[K' \neq K | K' \leftarrow \text{Decap}(sk, pk, C)] \leq \delta$$

KEM is perfectly correct if $\delta = 0$.

FO-KEM with Implicit Rejection. The Fujisaki–Okamoto (FO) transform introduced in [49,50] is a common construction used to elevate the security of an IND-CPA PKE to an IND-CCA KEM [48]. As opposed to explicitly rejecting KEMs, most NIST PQC KEMs use variants of FO with implicit rejection ($\text{FO}_m^\perp$), where the decryption routine still outputs a random key from the same key space, even if the decryption fails. Throughout the rest of the paper, it is implied

that any used KEM is an FO_m^χ KEM as depicted in Fig. 3. This type of KEM construction can be viewed as a generalization for most LWE (and variants thereof) KEMs: it is used in CRYSTALS-Kyber, FrodoKEM, NewHope and Korea PQC competition winner SMAUG-T¹.

KEM.KGen(1^κ)	KEM.Encap(pk)	KEM.Decap(sk', pk, C)
$(pk, sk) \leftarrow \text{PKE.KGen}(1^\kappa)$	$m \leftarrow \$ \mathcal{M}$	$m' \leftarrow \text{PKE.Dec}(sk, C)$
$s \leftarrow \$ \{0, 1\}^{ s }$	$(r, k) \leftarrow G_2(G_1(pk), m)$	$(r', k') \leftarrow G_2(G_1(pk), m')$
$sk' \leftarrow (s, sk, pk, G_1(pk))$	$C \leftarrow \text{PKE.Enc}(pk, m; r)$	$C' \leftarrow \text{PKE.Enc}(pk, m'; r')$
return (pk, sk')	$K \leftarrow F(k, C)$	if $C' = C$ then
	return (C, K)	return $K' \leftarrow F(k', C)$
		else return $K' \leftarrow F(s, C)$

Fig. 3. FO_m^χ KEM with pk as explicit input to Decap using a PKE with message space $\mathcal{M}$ and hash functions G_1, G_2 and F . The output of G_2 depends on pk and m and can be viewed as a concatenation of r and k as in e.g., Kyber [51] using SHA-512 for G_2 - Adapted from [52,48,53].

Security of KEM. The basic security of a KEM is defined in terms of indistinguishability of encapsulated keys from random keys. The anonymity and collision freeness of a KEM also play an essential role in the context of protocol design in general, and PAKEs in particular, as they capture properties beyond key security and protect against other distinguishing and collision finding attacks [48,53,8]. Further, we adopt the notion of public key uniformity for a KEM, which was introduced in [4] and [5] as the *Fuzziness* property, and later formalized in [6]. We deem this property vital in the context of PAKE dictionary attacks, as it prevents adversaries from distinguishing honestly generated public keys from randomly generated ones, and consequently excluding wrong password guesses within a PAKE execution. The KEM security properties relevant for our construction are described in the experiments $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{IND-CCA}^b}$, $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{PKU}^b}$, $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{ANO-CCA}^b}$ and $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{SCFR-CCA}}$ respectively in (Fig. 4).

Definition 8 (Key Uniformity of KEMs). For a key encapsulation mechanism KEM with public key space $\mathcal{PK}$, we define the advantage of an adversary $\mathcal{A}$ in distinguishing honestly generated public keys from uniform random ones as $\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{PKU}}(1^\kappa)$ where $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{PKU}^b}(1^\kappa)$ is the security game in Fig. 4.

Definition 9 (IND-CCA security of KEM). For a key encapsulation mechanism KEM with session key space $\mathcal{K}$, define the advantage of an adversary $\mathcal{A}$ in distinguishing genuinely encapsulated session keys from uniform random ones as $\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{IND-CCA}}(1^\kappa)$ where $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{IND-CCA}^b}(1^\kappa)$ is the security game in Fig. 4.

¹ Our syntax later on will require Decap to take the public key as an explicit input, but Fig. 3 also reflects how many LWE-based KEMs have the public key as part of the secret key (to perform FO decapsulation).

$\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{PKU}^b}(1^\kappa)$	$\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{IND-CCA}^b}(1^\kappa)$
1 : $(pk_0, sk_0) \leftarrow \text{KGen}(1^\kappa)$	1 : $(pk, sk) \leftarrow \text{KGen}(1^\kappa)$
2 : $pk_1 \leftarrow \$ \mathcal{PK}$	2 : $(C^*, K_0) \leftarrow \text{Encap}(pk)$
3 : $b' \leftarrow \mathcal{A}(pk_b)$	3 : $K_1 \leftarrow \$ \mathcal{K}$
4 : return $b = b'$	4 : $b' \leftarrow \mathcal{A}^{\text{D}(sk, pk, \cdot)}(pk, C^*, K_b)$
	5 : return $b = b'$
$\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{ANO-CCA}^b}(1^\kappa)$	$\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{SCFR-CCA}}(1^\kappa)$
1 : $(pk_0, sk_0) \leftarrow \text{KGen}(1^\kappa)$	1 : $(pk_0, sk_0) \leftarrow \text{KGen}(1^\kappa)$
2 : $(pk_1, sk_1) \leftarrow \text{KGen}(1^\kappa)$	2 : $(pk_1, sk_1) \leftarrow \text{KGen}(1^\kappa)$
3 : $(C^*, K^*) \leftarrow \text{Encap}(pk_b)$	3 : $C \leftarrow \mathcal{A}^{\text{D}(\cdot, \cdot)}(pk_0, pk_1)$
4 : $b' \leftarrow \mathcal{A}^{\text{D}(\cdot, \cdot)}(pk_0, pk_1, (C^*, K^*))$	4 : $K_0 \leftarrow \text{Decap}(pk_0, sk_0, C)$
5 : return $b = b'$	5 : $K_1 \leftarrow \text{Decap}(pk_1, sk_1, C)$
	6 : return $K_0 = K_1 \neq \perp$

Fig. 4. KEM Experiments $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{PKU}^b}$, $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{IND-CCA}^b}$, $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{ANO-CCA}^b}$ and $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{SCFR-CCA}}$. The experiments IND-CCA, ANO-CCA and SCFR-CCA are adopted from [53]. The decapsulation oracle D takes a ciphertext and a bit that selects which secret key to use and disallows queries on the challenge ciphertext where applicable (ANO-CCA and IND-CCA). The Decap routine in $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{SCFR-CCA}}$ explicitly takes an input parameter pk_i as in [48]. CPA versions of the aforementioned properties can be obtained by omitting the decryption oracles from the experiments.

Definition 10 (ANO-CCA security of KEM). For a key encapsulation mechanism KEM with public key space $\mathcal{PK}$, define the advantage of an adversary $\mathcal{A}$ in distinguishing public keys used to probabilistically encapsulate keys into ciphertexts as $\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{ANO-CCA}}(1^\kappa)$ where $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{ANO-CCA}^b}(1^\kappa)$ is the security game in Fig. 4.

Definition 11 (SCFR-CCA security of KEM). For a key encapsulation mechanism KEM with public key space $\mathcal{PK}$ and session key space $\mathcal{K}$, define the advantage of an adversary $\mathcal{A}$ in probabilistically generating a ciphertext C that decapsulates correctly under two unique public keys and their corresponding secret keys as $\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{SCFR-CCA}}(1^\kappa)$ where $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{SCFR-CCA}}(1^\kappa)$ is the security game in Fig. 4.

We note that KEMs with implicit rejection satisfying the collision freeness property (SCFR-CCA) cannot satisfy the strong robustness property [53,48] (SROB-CCA). Although SROB is defined via an almost identical experiment to SCFR, the fact that the latter rules out rejecting a decapsulated key through the provided KEM interface cannot be interpreted the same way as in the former. Whereas SROB guarantees that a ciphertext cannot decapsulate correctly under two different key pairs, SCFR only ensures that a ciphertext cannot produce the exact same (identical) key under two different key pairs.

3.5 Lattice KEMs with Splittable Public Keys

KEMs based on the lattice LWE problem and its variants have public keys of the form $pk : (\mathbf{A}, \mathbf{b} = \mathbf{A}\mathbf{s} + \mathbf{e})$, where a matrix $\mathbf{A}$ defines the base of the lattice expanded from a random seed (fixed-length bit string usually referred to as ρ) that is appended (or prepended) to the public key. In the following we shall refer to such KEMs as a subset of the previously defined KEMs in Def. 6, which can be obtained from an LWE-based PKE with splittable public keys (Fig. 5).

$\text{PKE.Enc}(pk, m; r)$
$(\mathbf{A}, \mathbf{b}) \leftarrow pk$ // Parse pk to lattice base and uniform sample
$(\mathbf{r}, \mathbf{e}_1, \mathbf{e}_2) \leftarrow r$ // Sample secrets from randomness
$\mathbf{u} := \mathbf{A}^T \mathbf{r} + \mathbf{e}_1$ // Direct usage of $\mathbf{A}$
$\mathbf{v} := \mathbf{b}^T \mathbf{r} + \mathbf{e}_2 + m$ // Indirect usage of $\mathbf{A}$ as in $\mathbf{b} = \mathbf{A}\mathbf{s} + \mathbf{e}$ (simplified)
return $C := (\mathbf{u}, \mathbf{v})$

Fig. 5. Simplified exposition of encryption using an internal PKE in a lattice LWE KEM with splittable public keys of the form $pk : (\mathbf{A}, \mathbf{b} = \mathbf{A}\mathbf{s} + \mathbf{e})$. Inputs to PKE.Enc are passed down from KEM as in Fig. 3.

Definition 12 (The Split $(\mathbf{A}, \mathbf{b}) \leftarrow \text{Split}(pk)$). Let KEM be a key encapsulation mechanism with public keys of the form $pk : (\mathbf{A}, \mathbf{b} = \mathbf{A}\mathbf{s} + \mathbf{e})$ defined over public key space $\mathcal{PK}$, where pk is a simple concatenation of two bit strings ρ and $\mathbf{b}$ (in any given order). Then: $\text{Split}(pk)$ is the function that trivially decomposes pk into the two said components $\mathbf{b}$ and ρ , and Split^{-1} is its reverse operation. In the following, we simplify the notation to $(\mathbf{A}, \mathbf{b}) \leftarrow (pk)$ for ease of exposition.

Recall that in such KEMs, a PKE is used for encryption and decryption (Fig. 3), where the $\mathbf{A}$ -part is used by the encapsulator both indirectly to encrypt a message m and directly to encrypt a randomness $\mathbf{r}$ (Fig. 5). When decapsulating a ciphertext C to obtain K , the decapsulator also learns the message m encrypted using the internal PKE. This is unavoidable for any PKE-based KEM with splittable public keys, as the ciphertext containing m needs to be decrypted before deriving K from m [48]. Further, the encryption yields a ciphertext of the form $(\mathbf{u}, \mathbf{v})$ (Fig. 5), where $\mathbf{v}$ represents the encrypted message m chosen by the encapsulator using the $\mathbf{b}$ -part, and $\mathbf{u}$ is the encryption of the encapsulators own uniformly chosen randomness. To decrypt $(\mathbf{u}, \mathbf{v})$, the decapsulator must use the same $\mathbf{A}$ -part as the encapsulator, otherwise they cannot decrypt the message m . Adapting the definition in [9] we specify the subset of KEMs that are in scope in the rest of the document. It follows²:

Definition 13 (LWE KEM with Splittable Public Keys (LS-KEM)). Let KEM be a key encapsulation mechanism (Def. 6) and $l \in \mathbb{N}$. We say that KEM is as an LWE-based KEM with splittable public keys, and call it LS-KEM, if:

² See [9] for a more formal definition, here we simplify for ease of exposition.

- it uses the Fujisaki-Okamoto (FO_m^χ) transform as defined in Fig. 3,
- it utilizes an underlying PKE following the syntax defined in Fig. 5 (and therefore has public keys of the form $pk := (\mathbf{A}, \mathbf{b} = \mathbf{A}\mathbf{s} + \mathbf{e})$), and
- $\mathbf{A}$ is computed (expanded) from $\rho \in \{0, 1\}^l$ via a deterministic function G .

4 Novel Security Properties for Splittable KEMs

We introduce the security properties for KEMs with splittable public keys (LS-KEM) of the form $pk : (\mathbf{A}, \mathbf{b} = \mathbf{A}\mathbf{s} + \mathbf{e})$, where $\mathbf{A}$ is deterministically computed (expanded) from a fixed-length random bit string seed ρ , and is thus chosen from the $\mathbf{A}$ -part space $\mathbb{A}$, the set of uniform distributed lattice matrices of the same size as the matrices probabilistically generated using KEM.KGen .

4.1 Key Uniformity of KEM with Splittable Public Keys

Based on the general KEM public key uniformity (cf. Sec. 3.4 Def. 8), we derive a similar notion for our previously defined LS-KEM, the security experiment of which is shown in Fig. 6. We claim with this extension of the original notion, and the UNI-PK notion of Arriaga et al. [9], that an adversary viewing only a $\mathbf{b}$ -part of the public key is not able to distinguish the $\mathbf{A}$ -part embedded in it as $\mathbf{A}\mathbf{s} + \mathbf{e}$ from one that is chosen uniformly at random. The proof of UNI-PK for MLWE (e.g., Kyber) follows from [9], and can be similarly shown for LWE (e.g., FrodoKEM) via a trivial reduction from the decisional LWE assumptions.

Definition 14 (Key Uniformity of KEM with Splittable Public Keys).

For LS-KEM with public key space $\mathcal{PK}$ and $\mathbf{A}$ -part space $\mathbb{A}$, we define the advantage of an adversary $\mathcal{A}$ in distinguishing an honestly embedded $\mathbf{A}$ -part in public keys from uniformly random ones as $\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{SPLIT-PKU}}(1^\kappa)$ where $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{SPLIT-PKU}}(1^\kappa)$ is the game in Fig. 6.

$\text{Exp}_{\text{KEM}, \text{Split}}^{\text{UNI-PK}^b}(\mathcal{A})$	$\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{SPLIT-PKU}^b}(1^\kappa)$
1 : $(pk_0, -) \leftarrow \text{KGen}(1^\kappa)$	1 : $(pk_0, sk_0) \leftarrow \text{KGen}(1^\kappa)$
2 : $(r_0, M_0) \leftarrow \text{Split}(pk_0)$	2 : $(\mathbf{A}_0, \mathbf{b}_0) \leftarrow pk_0$
3 : $(r_1, M_1) \leftarrow N_\kappa \times R_\kappa$	3 : $\mathbf{A}_1 \leftarrow \$ \mathbb{A}$
4 : $b' \leftarrow \mathcal{A}(r_b, M_b)$	4 : $b' \leftarrow \mathcal{A}(\mathbf{A}_b, \mathbf{b}_b)$
5 : return $b == b'$	5 : return $b == b'$

Fig. 6. Key Uniformity for LS-KEM. UNI-PK (left) is adopted from [9] in original notation where Split is an invertible map $\mathcal{PK}_\kappa \rightarrow N_\kappa \times R_\kappa$ s.t $r \in N_\kappa$ is a fixed-length seed and $M \in R_\kappa$ is a lattice sample, which corresponds to our experiment (right).

Theorem 3. Let LS-KEM be the key encapsulation mechanism defined in Def. 13, where $\mathbf{A}$ is deterministically computed from the $\mathbf{A}$ -part space $\mathbb{A}$ via a uniformly

sampled fixed-length bit string seed ρ using the function G modeled as a RO, then the advantage of an adversary against SPLIT-PKU can be expressed as follows:

$$\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{SPLIT-PKU}}(1^\kappa) \leq \text{Adv}_{\mathcal{B}, \text{KEM}}^{\text{UNI-PK}}(1^\kappa)$$

Proof (Theorem 3). Recall that $\mathbf{A}$ is deterministically expanded from a fixed-length bit string ρ using the function G . It is hence obvious that sampling from the exact same bit string will always yield the same $\mathbf{A}$ -part using the same function modeled as a RO. It follows that parsing $\mathbf{A}_0$ from pk_0 in line 2 of $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{SPLIT-PKU}}(1^\kappa)$ is indeed equivalent to parsing r_0 in line 2 of $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{UNI-PK}}(1^\kappa)$, and then sampling $\mathbf{A}_0 \leftarrow G(r_0)$. Similarly, sampling from another unique bit string will yield a different and unique $\mathbf{A}$ -part, which respectively corresponds to line 3 of each of said experiments. Now suppose there is an adversary $\mathcal{A}$ that wins in the $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{SPLIT-PKU}}(1^\kappa)$ game. We show an adversary $\mathcal{B}$ that succeeds against the $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{UNI-PK}}(1^\kappa)$ game with approximately the same advantage. The reduction is trivial: $\mathcal{B}$ plays the $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{UNI-PK}}(1^\kappa)$ until line 3, and then samples $\mathbf{A}_0 \leftarrow G(r_0)$ and $\mathbf{A}_1 \leftarrow G(r_1)$ respectively. Then $\mathcal{B}$ forwards these values to $\mathcal{A}$ with either M_0 or M_1 . $\mathcal{A}$ then outputs a bit b and forwards their guess to $\mathcal{B}$. Now, as the seed is simply a random bit string, the initial $\mathbf{b}$ -part of the key in line 2 can be viewed as pseudo uniform (see [9], Theorem 2), and hence it is equivalent to M_b in line 4 of $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{UNI-PK}}(1^\kappa)$. It follows that if the adversary $\mathcal{A}$ succeeds in deciding SPLIT-PKU, then $\mathcal{B}$ can succeed in deciding UNI-PK with approximately the same advantage.

4.2 A-Part Secrecy for KEM with Splittable Public Keys

Based on the definitions in Sec. 3.3, 3.4, and 3.5, we rely on the fact that the $\mathbf{u}$ -part in C resembles a chosen sample that belongs to the same hardness assumption of the chosen KEM (i.e., LS-KEM), so that it is not possible to determine which $\mathbf{A}$ was used to create $\mathbf{u}$. This assumption plays an essential role in our security analysis in Sec. 5. Formally, we claim that using a different $\mathbf{A}$ -part for encryption results in ciphertexts that cannot be decrypted correctly and cannot be used to reveal a non-related $\mathbf{A}$. We formalize this claim as KEM A-Part Secrecy (A-SEC-CCA) depicted in Fig. 7, and prove its correctness.

Definition 15 (Splittable KEM A-Part Secrecy). For LS-KEM with public key space $\mathcal{PK}$ and $\mathbf{A}$ -part space $\mathbb{A}$, we define the advantage of an adversary $\mathcal{A}$ in distinguishing a random $\mathbf{A}$ -part of a known public key used to probabilistically generate a ciphertext as $\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{A-SEC-CCA}}(1^\kappa)$ where $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{A-SEC-CCA}}(1^\kappa)$ is the game depicted in Fig. 7.

Remark on property idea. Unlike the standard anonymity notion, we want to explicitly capture the case where an adversary controls the key generation. As we will discuss in detail in Sec. 6.1, our PAKE protocol (and its analysis) requires both parties to detect ciphertexts generated using malicious key material: this

$\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{A-SEC-CCA}^b}(1^\kappa)$	$\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{A-SEC-CCA}^{(b, \mathcal{D})}}(1^\kappa)$
1 : $(pk, sk) \leftarrow \mathcal{A}$	1 : $(pk, sk) \leftarrow \mathcal{A}$
2 : $\mathbf{A}_0 \leftarrow \$ \mathbb{A}$	2 : $\mathbf{A}_0 \leftarrow \$ \mathcal{D}$
3 : $\mathbf{A}_1 \leftarrow \$ \mathbb{A}$	3 : $\mathbf{A}_1 \leftarrow \$ \mathbb{A}$
4 : $(C, K) \leftarrow \text{Encap}'_{\mathbf{A}_b}(pk)$	4 : $(C, K) \leftarrow \text{Encap}'_{\mathbf{A}_b}(pk)$
5 : $b' \leftarrow \mathcal{A}(C, pk, sk, \mathbf{A}_0, \mathbf{A}_1)$	5 : $b' \leftarrow \mathcal{A}(C, pk, sk, \mathbf{A}_0, \mathbf{A}_1)$
6 : if !validate($pk[\mathbf{A}_b], C, K$)	6 : if !validate($pk[\mathbf{A}_b], C, K$)
7 : $b' \leftarrow \$ \{0, 1\}$	7 : $b' \leftarrow \$ \{0, 1\}$
8 : return $b == b'$	8 : return $b == b'$

Fig. 7. **A**-Part Secrecy Experiment (Left) and w.r.t. Password Dictionary (Right), where $\mathbb{A}$ and $\mathcal{D}$ denote the lattice matrix space and password dictionary space respectively, and $\text{KEM}.\text{Encap}'_{\mathbf{A}}(pk)$ denotes invoking Encap explicitly with a matrix $\mathbf{A}_b$, i.e. ignoring the one embedded in pk (that was initially chosen by $\mathcal{A}$). The ciphertext validity check is defined in Sec. 6.1.

step is also necessary in this game to disallow trivial wins through re-encryption. We therefore incorporate the ciphertext validity check and abort if C can be trivially decapsulated (without the secret key sk), where the validity check is called using the **A**-part used in the experiment and the **b**-part provided by the adversary $\mathcal{A}$.

Remark on usage in PAKE formal analysis. Since an adversary is restricted by forwarding a masked seed ρ , we show that even with a prepared list of all possible passwords and hash outputs, an adversary cannot leverage a brute-force (offline dictionary) attack to guess the correct password. Here, we follow the BPR definition of $\mathcal{D}$ assuming a uniform distribution of passwords within the dictionary. Thus, any seed obtained from unmasking z follows the same distribution, since the masked seed is an unstructured random bit string.

Theorem 4. *Let LS-KEM be the key encapsulation mechanism defined in Def. 13 where $\mathbf{A}$ is deterministically computed from the **A**-part space $\mathbb{A}$ via a uniformly sampled fixed-length bit string seed ρ using the function G modeled as a RO, then the advantage of an adversary against A-SEC-CCA can be expressed as follows:*

$$\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{A-SEC-CCA}}(1^\kappa) \leq 1/2 + \varepsilon_{\text{whLWE}} + \text{negl}(1^\kappa)$$

Remark on concrete A-SEC-CCA-security. In the following, we show that the **A**-Part Secrecy (A-SEC-CCA) property applies to LS-KEM as previously defined in Sec. 3.5 (Def. 13) that is instantiated with any FrodoKEM-style plain LWE PKE. We will show that the concrete security loss using FrodoKEM (cf. Sec. 6), as presented in NIST PQC Round 3, is only a few bits of security. Specifically, it depends on concrete parameters of the associated whLWE problem. Full NIST concrete security levels can be achieved by mild re-parameterizations of FrodoKEM (within its well-defined design space) inducing a minimal loss in practical efficiency.

Remark on terminology. We refer to FrodoKEM in what follows, with the understanding that we either use FrodoKEM as defined but lose a few bits of security, or an alternative “GimliKEM,”³ with slightly larger keys and ciphertexts, where the security proof equally applies but with no loss in concrete security.

Proof (Theorem 4). We show A-SEC-CCA security using the common game-based approach, starting with the original security game $\mathbf{G}_0$, and transitioning through a series of experiments $\mathbf{G}_1, \mathbf{G}_2, \dots$ while bounding the adversary’s advantage. The final game will be independent of the challenge bit b , giving the theorem. Specifically, we aim to swap the portion of the ciphertext C that depends on $\mathbf{A}_b$ to uniform. Note that if the ciphertext validity check fails, then $\text{Adv}_{\mathbf{A}, \text{KEM}}^{\text{A-SEC-CCA}}(1^\kappa) = 0$ and therefore the following proof only considers the case where the check passes.

Game $\mathbf{G}_0$. This is the original game. The adversary chooses pk, sk arbitrarily. While $pk = (\mathbf{A}, \mathbf{b})$, only $\mathbf{b}$ is used in constructing C . Then, $\mathbf{A}_0$ is computed from distribution $\mathcal{D}$, which is a well-spread depending on the entropy of the password π with support in the $\mathbf{A}$ -space of the KEM, and $\mathbf{A}_1$ is chosen uniformly from the $\mathbf{A}$ -space of the KEM. The challenger flips a bit b then constructs the challenge ciphertext C (ignoring the message component) of the form:

$$\begin{aligned} C &= (u, v) \\ u &= \mathbf{A}_b \mathbf{r} + \mathbf{e}' \\ v &= \mathbf{b} \mathbf{r} + \mathbf{e}'' \end{aligned}$$

The adversary’s view in $\mathbf{G}_0$ is $(C, pk, sk, \mathbf{A}_0, \mathbf{A}_1)$ and outputs a guess b' as to which matrix $\mathbf{A}_b$ was used in constructing the ciphertext C .

Game $\mathbf{G}_1$. In this hybrid, we swap $\mathbf{A}_0$ to be chosen uniformly from the $\mathbf{A}$ -space of the KEM. The rest of the experiment is the same.

Lemma 2 ($\mathbf{G}_0 \stackrel{\text{comp}}{\approx} \mathbf{G}_1$). *If G is modeled as a RO and Non-uniform LWE is $(1 - \text{negl}(1^\kappa))$ -hard, then $\Pr_{\mathbf{G}_0}[\mathcal{A} \text{ wins}] \leq \Pr_{\mathbf{G}_1}[\mathcal{A} \text{ wins}] + \text{negl}(1^\kappa)$.*

Proof (Lemma 2). The difference in the games is the distribution of $\mathbf{A}_0$. In the first one, $\mathcal{A}$ ’s view of $\mathbf{A}_0$ is no worse than having computed $\mathbf{A}_0$ as the output of a RO, which was given as input a randomly chosen password π . We claim that, conditioned on the entropy of π being well-spread and uniform distributed in $\mathcal{D}$, this distribution is n -coset samplable in a straightforward way. Following [44, Remark 4.4]: even when $\mathbf{r}$ is distributed according to the error distribution, NLWE is hard. Yet, $\mathcal{A}$ additionally has leakage on $\mathbf{r}$ in the form of $v = \mathbf{b} \mathbf{r} + \mathbf{e}''$. However, since $\mathbf{b}$ is chosen by the adversary *non-adaptively* – that is, before seeing $(\mathbf{A}_0, \mathbf{A}_1)$ – this leakage is independent of the n -coset samplability of $\mathbf{A}_0$. Therefore, n -coset samplability of $\mathbf{A}_0$ follows solely from modeling G as a RO, so distinguishing $\mathbf{G}_0$ and $\mathbf{G}_1$ is as hard as NLWE.

³ Gimli was another member of the Fellowship, who was slightly larger than Frodo but had a nice axe.

Game $\mathbf{G}_2$. In this hybrid, we swap the u -part of the challenge ciphertext C to uniform. The rest of the experiment remains the same.

Lemma 3 ($\mathbf{G}_1 \stackrel{\text{comp}}{\approx} \mathbf{G}_2$). *For $\varepsilon_{\text{whLWE}} < 1$, if Weak-Hint LWE is $(1 - \varepsilon_{\text{whLWE}})$ -hard, then $\Pr_{\mathbf{G}_1}[\mathcal{A} \text{ wins}] \leq \Pr_{\mathbf{G}_2}[\mathcal{A} \text{ wins}] + \varepsilon_{\text{whLWE}}$.*

Proof (Lemma 3). The difference between the games is the distribution of u . In $\mathbf{G}_1$, we have $u = \mathbf{A}_b \mathbf{r} + \mathbf{e}'$, and in $\mathbf{G}_2$, we have u sampled uniformly at random. The adversary's view of the challenge ciphertext $C = (u, v)$ includes the hint $v = \mathbf{b} \mathbf{r} + \mathbf{e}''$ on the ciphertext's secret $\mathbf{r}$ that defines the LWE instance considered, where $\mathbf{b}$ is *arbitrarily chosen* by the adversary. The adversary chooses $\mathbf{b}$ and hands it to the challenger. The challenger flips a coin and returns either

$$\begin{array}{ccc} C = (u, v) & & C = (u, v) \\ u = \mathbf{A}_b \mathbf{r} + \mathbf{e}' & \text{or} & u = \text{uniform} \\ v = \mathbf{b} \mathbf{r} + \mathbf{e}'' & & v = \mathbf{b} \mathbf{r} + \mathbf{e}'' \end{array}$$

In the first case, the challenger simulates $\mathbf{G}_1$; in the second case, the challenger simulates $\mathbf{G}_2$. Therefore, the adversary's advantage in distinguishing the hybrids is its advantage $\varepsilon_{\text{whLWE}}$ against the Weak-Hint LWE problem with appropriate parameters (concrete parameters discussed in Sec. 6.2).

Completing the proof of Theorem 4. Finally, in $\mathbf{G}_2$, we note that the adversary's view is independent of the bit b in the A-SEC-CCA^(b,D) security experiment. Therefore, $\Pr_{\mathbf{G}_2}[\mathcal{A} \text{ wins}] = 1/2$. Combining Lemmas 2 and 3, we have the probability that the adversary wins in the original A-SEC-CCA security game is $\Pr_{\mathbf{G}_0}[\mathcal{A} \text{ wins}] \leq 1/2 + \text{negl}(1^\kappa) + \varepsilon_{\text{whLWE}}$, which gives Theorem 4.

Corollary 1 (A-SEC-CCA Security for MLWE). *If Non-Uniform MLWE (NMLWE) is $(1 - \text{negl}(1^\kappa))$ -hard and Extended MLWE (EMLWE) is $(1 - \text{negl}(1^\kappa))$ -hard (cf. App. C.2 and App. C.3), and if there exists a reduction from MLWE to whMLWE, which closely preserves the adversary's advantage against (MLWE), then it follows a similar proof for Theorem 4 for any LS-KEM instantiated from MLWE hardness assumptions (e.g., CRYSTALS-Kyber), the concrete parameters of which are discussed in Section 6.*

4.3 Collision Freeness for KEM with Splittable Public Keys

Analogous to the formerly introduced A-SEC-CCA property, we suggest the notion of A-Part-Collision-Freeness A-CFR-CCA, or Splittable Collision Freeness.

Definition 16 (Splittable KEM Collision Freeness). *For a key encapsulation mechanism LS-KEM with public key space $\mathcal{PK}$ and $\mathbf{A}$ -part space $\mathbb{A}$, we define the advantage of an adversary $\mathcal{A}$ in probabilistically generating a ciphertext C that decapsulates correctly under two unique $\mathbf{A}$ -parts under the same $\mathbf{b}$ -part and secret key sk as $\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{A-CFR-CCA}}(1^\kappa)$ where $\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{A-CFR-CCA}}(1^\kappa)$ is the game in Fig. 8.*

Remark on property idea. Following Cremers et al. [48], SCFR-CCA for a KEM means that together, the output key and the ciphertext bind the public key; i.e., changing the public key changes the other two components by a sufficient distance, so that they both become statistically independent across different public keys. We argue that the $\mathbf{A}$ -part of the public key has enough entropy to change the output key in both KEM.Encap and KEM.Decap routines, so that the resulting keys are not systematically relatable to each other. Thus, the adversary's goal in the A-CFR-CCA game (Fig. 8) is to enforce a collision on ciphertexts so that they decapsulate to matching (i.e., identical) keys although encapsulated with different $\mathbf{A}$ -parts.

$\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{A-CFR-CCA}}(1^\kappa)$	$\text{Exp}_{\mathcal{A}, \text{KEM}}^{\text{A-CFR-CCA}^\mathcal{D}}(1^\kappa)$
1 : $(pk, sk) \leftarrow \text{KGen}(1^\kappa)$	1 : $(pk, sk) \leftarrow \text{KGen}(1^\kappa)$
2 : $(\mathbf{A}, \mathbf{b}) \leftarrow pk$	2 : $(\mathbf{A}, \mathbf{b}) \leftarrow pk$
3 : $\mathbf{A}^* \leftarrow \$ \mathbb{A}$	3 : $\mathbf{A}^* \leftarrow \$ \mathcal{D}$
4 : $C \leftarrow \mathcal{A}^{\text{D}(\dots)}(\mathbf{b}, \mathbf{A}, \mathbf{A}^*)$	4 : $C \leftarrow \mathcal{A}^{\text{D}(\dots)}(\mathbf{b}, \mathbf{A}, \mathbf{A}^*)$
5 : $K \leftarrow \text{Decap}'(\mathbf{b}, \mathbf{A}, sk, C)$	5 : $K \leftarrow \text{Decap}'(\mathbf{b}, \mathbf{A}, sk, C)$
6 : $K^* \leftarrow \text{Decap}'(\mathbf{b}, \mathbf{A}^*, sk, C)$	6 : $K^* \leftarrow \text{Decap}'(\mathbf{b}, \mathbf{A}^*, sk, C)$
7 : return $K = K^* \neq \perp$	7 : return $K = K^* \neq \perp$

Fig. 8. $\mathbf{A}$ -Part Collision Freeness (Left) and w.r.t. Password Dictionary (Right), where $\mathbb{A}$ and $\mathcal{D}$ denote the lattice matrix space and password dictionary space respectively, and $\text{KEM.Decap}'(\mathbf{b}, \mathbf{A}, sk, C)$ denotes invoking Decap explicitly with a chosen matrix $\mathbf{A}$ not necessarily matching the one embedded in $\mathbf{b}$.

Theorem 5. *Let LS-KEM be the key encapsulation mechanism defined in Def. 13, where $\mathbf{A}$ is deterministically computed from the $\mathbf{A}$ -part space $\mathbb{A}$ via a uniformly sampled fixed-length bit string seed p using the function G modeled as a RO, then the advantage of an adversary against A-CFR-CCA can be expressed as follows:*

$$\text{Adv}_{\mathcal{A}, \text{KEM}}^{\text{A-CFR-CCA}}(1^\kappa) \leq \text{Adv}_{\mathcal{B}_1, \text{KEM}}^{\text{SPLIT-PKU}}(1^\kappa) + \text{Adv}_{\mathcal{B}_2, \text{KEM}}^{\text{SCFR-CCA}}(1^\kappa) + \text{negl}(1^\kappa)$$

Proof (Theorem 5). In order to show A-CFR-CCA security, we use the common game based approach, starting with the original security game $\mathbf{G}_0$ and transitioning to a new experiment $\mathbf{G}_1$ while bounding the adversary's advantage. This latter game will be shown hard based on the hardness of SCFR-CCA.

Game $\mathbf{G}_0$. This is the original game. Here, the challenger first generates pk, sk honestly. $\mathbf{A}$ is obtained from splitting $\mathbf{b}$, and is thus uniformly chosen from the $\mathbf{A}$ -space of the KEM. Then, $\mathbf{A}^*$ is computed from distribution $\mathcal{D}$, which is a well-spread distribution depending on the entropy of the password π with support in the $\mathbf{A}$ -space of the KEM. While $pk = (\mathbf{A}, \mathbf{b})$, only the $\mathbf{b}$ term is fixed. The adversary can thus freely choose whether to encapsulate using $\mathbf{A}$ or $\mathbf{A}^*$, and they use one of those with $\mathbf{b}$ to construct C . The challenger receives C from the

adversary and invokes KEM.Decap twice using both $\mathbf{A}$ -parts and obtains K and K^* respectively. The encapsulation routine of the KEM (as shown in Fig. 3) is:

```

 $(k, \mathbf{r}) = G_2(G_1(pk) || m)$ 
 $C \leftarrow \text{PKE.Enc}(m, pk; \mathbf{r})$ 
 $K \leftarrow F(C || k)$ 
return  $(C, K)$ 

```

where G_1 , G_2 and F are RO-modeled hash functions. The adversary's view in $\mathbf{G}_0$ is $(C, \mathbf{b}, \mathbf{A}, \mathbf{A}^*)$ and the challenger checks: K and K^* are equal and not rejected. For KEMs with implicit rejection the challenger only checks if $K = K^*$.

Game $\mathbf{G}_1$. In this step, we swap the $\mathbf{A}$ -part in pk to be chosen uniformly from the $\mathbf{A}$ -space of the KEM. The rest of the experiment is the same.

Lemma 4 ($\mathbf{G}_0 \stackrel{\text{comp}}{\approx} \mathbf{G}_1$). *If G is modeled as a RO and Non-uniform LWE is $(1 - \text{negl}(1^\kappa))$ -hard, then*

$$\Pr_{\mathbf{G}_0}[\mathcal{A} \text{ wins}] \leq \Pr_{\mathbf{G}_1}[\mathcal{A} \text{ wins}] + \text{negl}(1^\kappa)$$

Proof (Lemma 4). The difference in the games is the distribution of $\mathbf{A}$. In the first game, $\mathcal{A}$'s view of $\mathbf{b}$ does not allow him to identify the $\mathbf{A}$ -part embedded in $\mathbf{b}$ by the hardness of Non-uniform LWE (similar to the proof of Lemma 2). Thus, with the output of the function G_1 being modeled as a RO, inputting a pseudo-random pk as per Definition 14 will yield a statistically independent value, with probability bound by the advantage against $\text{Exp}_{\mathcal{B}_1, \text{KEM}}^{\text{SPLIT-PKU}}$ for some adversary $\mathcal{B}_1$. Hence we derive

$$\Pr_{\mathbf{G}_0}[\mathcal{A} \text{ wins}] \leq \Pr_{\mathbf{G}_1}[\mathcal{A} \text{ wins}] + \text{Adv}_{\text{KEM}}^{\text{SPLIT-PKU}}(\mathcal{B}_1)$$

Completing the proof of Theorem 5. Now, suppose there is an adversary $\mathcal{A}$ that wins with non-negligible probability in the A-CFR-CCA $^\mathcal{D}$ game. We show an adversary $\mathcal{B}_2$ that succeeds against the SCFR-CCA security experiment with $(1 - \text{negl}(1^\kappa))$ -close to the same probability. The reduction is trivial: $\mathcal{B}_2$ runs SCFR-CCA to line 3, then hands $(\mathbf{A}_0, \mathbf{A}_1, \mathbf{b}_0)$ to $\mathcal{A}$. When $\mathcal{A}$ outputs C , $\mathcal{B}_2$ outputs C in line 3 of the SCFR-CCA game. From the hardness of standard LWE, their probabilities of success are $\text{negl}(1^\kappa)$ close. From the hardness of SCFR-CCA via Grubbs et al. [53] and Cremers et al. [48], we get Theorem 5.

Corollary 2 (A-CFR-CCA Security for MLWE). *If Non-Uniform MLWE (NMLWE) is $(1 - \text{negl}(1^\kappa))$ -hard, then it follows a similar proof for Theorem 5 for any LS-KEM instantiated from MLWE hardness assumptions.*

5 Security Analysis of NICE-PAKE

The security analysis follows the BPR model for authenticated key exchange (AKE) [15]. It models an adversary in full control of the network, but without knowledge of the password, nor the secrets of honest users (e.g., the secret key in a KEM). The goal of an adversary is to distinguish real session keys as established by the protocol from random keys chosen independently. This is controlled by a **Test** query as defined in [15]. While many readers will already be familiar with this model, we defer the full model description to Appendix A.

Definition 17 (The NICE-PAKE Protocol). *Let $\mathcal{D}$ be a password dictionary ($\pi \in \mathcal{D}$), LS-KEM be a key encapsulation mechanism with key space $\mathcal{K}$ and seed length l as defined in Def. 13, and $\mathcal{H} : \mathcal{D} \rightarrow \{0, 1\}^l$. The protocol **NICE-PAKE** denoted by Π is depicted Fig. 1 using these building blocks.*

Correctness. The protocol Π is correct if the final session key matches for every pair of honest and partnered users $(\mathcal{U}_i, \mathcal{U}_j)$ with matching passwords $(\pi_{\mathcal{U}_i}, \pi_{\mathcal{U}_j}) \in \mathcal{D}$ in an honest protocol execution $\Pi(\mathcal{U}_i, \mathcal{U}_j)$. The correctness of Π depends on the correctness of the underlying KEM and is bounded by the KEM correctness parameter δ as defined in Sec. 3.4.

Theorem 6. *Let Π be the NICE-PAKE protocol defined in Fig. 1, instantiated over password dictionary $\mathcal{D}$ with a key encapsulation mechanism LS-KEM with splittable public keys and $\mathcal{H}$ modeled as a random oracle. The BPR advantage of an adversary $\mathcal{A}$ can then be bounded as follows, for adversaries $\mathcal{S}$, $\mathcal{B}_1$, $\mathcal{B}_2$, $\mathcal{B}_3$ and $\mathcal{B}_4$ that have similar running time to $\mathcal{A}$:*

$$\begin{aligned} \text{Adv}_{\mathcal{A}, \Pi}^{\text{BPR}}(1^\kappa) &\leq 2 \cdot (q_e^2 \cdot 2^{-|\rho|}) + |\mathcal{D}|^2 \cdot 2^{-|\rho|} \\ &\quad + 2q_e^2 \cdot \text{Adv}_{\mathcal{B}_1, \text{KEM}}^{\text{ANO-CCA}}(1^\kappa) \\ &\quad + 2q_s^2 \cdot |\mathcal{D}|^{-1} \cdot (\text{Adv}_{\mathcal{B}_2, \text{KEM}}^{\text{A-SEC-CCA}}(1^\kappa) \\ &\quad + \text{Adv}_{\mathcal{B}_3, \text{KEM}}^{\text{SPLIT-PKU}}(1^\kappa)) + 2q_s^2 \cdot \text{Adv}_{\mathcal{B}_4, \text{KEM}}^{\text{A-CFR-CCA}}(1^\kappa) \\ &\quad + (q_e^2 + q_s^2) \cdot 2\text{Adv}_{\mathcal{S}, \text{KEM}}^{\text{IND-CCA}}(1^\kappa) \end{aligned}$$

where (q_e, q_s) are the number of $\mathcal{A}$'s **Execute** and **Send** queries respectively, $|\mathcal{D}|$ is the password dictionary size and $|\rho| = \{0, 1\}^l$ is the **A**-part seed size of LS-KEM.

Proof (Theorem 6). We provide a security proof via the common game-based approach. We gradually modify the original security game $\mathbf{G}_0$ through a series of experiments $\mathbf{G}_1, \mathbf{G}_2, \dots$ showing that the success probability of an adversary cannot be significantly larger than $\frac{1}{2}$. The final game will be independent of the challenge bit b , giving the theorem. Specifically, we will aim to randomize the values transmitted on the network, which are visible for an adversary $\mathcal{A}$. We say the protocol Π is secure if the probability of $\mathcal{A}$ winning is bounded to a negligible quantity. We denote the probability of $\mathcal{A}$ winning in game $\mathbf{G}_i$ as $\Pr[\mathbf{G}_i]$.

Game $\mathbf{G}_0$. The original BPR security game.

Eliminating Collisions ($\mathbf{G}_1$ - $\mathbf{G}_3$):

Game $\mathbf{G}_1$ (Hash Collisions). Change Game $\mathbf{G}_0$ declaring the adversary to lose if there are distinct passwords $\pi \neq \pi' \in \mathcal{D}$ such that their hash values collide, $\mathcal{H}(\pi) = \mathcal{H}(\pi')$. The probability of this is bounded by the birthday bound as

$$\Pr[\mathbf{G}_0] \leq \Pr[\mathbf{G}_1] + |\mathcal{D}|^2 \cdot 2^{-|\rho|}.$$

This, in particular, means that we can assume that for each fixed value ρ , the function values $\rho \oplus \mathcal{H}(\pi)$, when varying over π , are all distinct.

Game $\mathbf{G}_2$ (Unique pk). Modify Game $\mathbf{G}_1$ by declaring the adversary to lose if there are two honest Alice-sessions (possibly with different passwords) which create the same initial message $(z, \mathbf{b})$. Note that each honest Alice-session picks a fresh random value ρ in each execution. Hence, the probability that this random value (shifted by $H(\pi)$ for Alice's password π in this session) matches the value $\rho' \oplus H(\pi')$ in another honest Alice-session is at most $q_e^2 \cdot 2^{-|\rho|}$. We derive

$$\Pr[\mathbf{G}_1] \leq \Pr[\mathbf{G}_2] + q_e^2 \cdot 2^{-|\rho|}.$$

Game $\mathbf{G}_3$ (Unique C_b). Modify Game $\mathbf{G}_2$ by declaring the adversary to lose if there are two honest Bob-sessions (possibly with different passwords) which create the same response message C_b . Note that the ciphertext C_b encapsulates a random message m from $\{0, 1\}^{|\rho|}$. This implies that the ciphertext space is of size at least $2^{|\rho|}$ and the ciphertext is chosen uniformly among such encryptions of messages m . Hence, the probability that a ciphertext C_b matches any of the $i \leq q_e$ previously chosen ciphertexts is at most $i \cdot 2^{-|\rho|}$ and thus

$$\Pr[\mathbf{G}_2] \leq \Pr[\mathbf{G}_3] + q_e^2 \cdot 2^{-|\rho|}.$$

Simulating the KEM ($\mathbf{G}_4$ - $\mathbf{G}_5$):

Modify Game $\mathbf{G}_3$ by having any honest Bob-session receiving a message $(z, \mathbf{b})$ from an honest Alice-session use $C_{b,\text{sim}}$ instead of C_b , where $(C_{b,\text{sim}}, \bar{K}'_{\text{sim}}) \leftarrow \text{KEM.Encap}(pk_{\text{sim}})$ for a fresh key pair $(sk_{\text{sim}}, pk_{\text{sim}}) \leftarrow \text{KEM.KGen}()$, for an independently sampled $\mathbf{A}_{\text{sim}}$. When the honest Alice-session which has sent $(z, \mathbf{b})$ (and which is unique by Game $\mathbf{G}_2$) receives this ciphertext $C_{b,\text{sim}}$, it uses the original key $\bar{K}'$ that Bob had encapsulated instead of decapsulating $C_{b,\text{sim}}$; the honest Bob-session also uses the key $\bar{K}'$ for the further steps. The indistinguishability of the hops from $\mathbf{G}_3$ to $\mathbf{G}_5$ is shown in two substeps.

Game $\mathbf{G}_4$ (Simulate KEM Key). First, we replace C_b by $C_{b,\text{sim}}$ for honest Bob-sessions (with an honest Alice-session partner) *but use the key $\bar{K}'_{\text{sim}}$ generated by Bob in the further steps*. We claim that this modification is indistinguishable

according to ANO-CCA. First, note that there can be at most q_e honest Bob-sessions with an honest Alice-session, and we can apply the above modification step-by-step. Second, ANO-CCA ensures that adversaries cannot gain information by forwarding ciphertexts to other connected sessions. Via a hybrid argument, we lose a factor q_s in the argument but can, from now on, focus on a single pair of sessions in which we replace Bob's values. It then follows via a straightforward reduction $\mathcal{B}$ to ANO-CCA, simulating the entire Game $\mathbf{G}_4$ (also picking the passwords of parties), and injecting the challenge key pairs (sk_0, pk_0) , (sk_1, pk_1) from the anonymity game into the Alice-session, using pk_0 as pk_a resp. using pk_1 as pk_{sim} in the Bob-session. The latter loses a factor q_s in the security bound to guess the correct Alice-session. If this happens, we immediately know the honest Bob-session communicating with this unique Alice-session. The anonymity game also gives us a challenge ciphertext C^* and key K^* , created either under pk_0 or under pk_1 . We use C^* as $C_{b,\text{sim}}$, and both parties use the key K^* as the session key. The reduction against anonymity outputs 1 if and only if adversary $\mathcal{A}$ wins the simulated game. Note that if C^*, K^* in the anonymity game are created under the public key pk_0 , then the simulation corresponds perfectly to game $\mathbf{G}_4$. If (C^*, K^*) is created under pk_1 then the simulation corresponds precisely to our intermediate game. It follows

$$\Pr[\mathbf{G}_3] \leq \Pr[\mathbf{G}_4] + 2q_e^2 \cdot \text{Adv}_{\mathcal{B}_1, \text{KEM}}^{\text{ANO-CCA}}(1^\kappa)$$

for some adversary $\mathcal{B}_1$, where the factor 2 stems from switching from a left-or-right game ANO-CCA to a comparison between games $\mathbf{G}_3$ and $\mathbf{G}_4$.

Game $\mathbf{G}_5$ (Use Original KEM Key). The next step now is to switch back to the original keys $\bar{K}'$ instead of $\bar{K}'_{\text{sim}}$ in such honest Alice-Bob-interactions. This follows now from the IND-CCA security of the KEM, saying that one cannot distinguish which of the two keys is encapsulated in $C_{b,\text{sim}}$. It follows

$$\Pr[\mathbf{G}_4] \leq \Pr[\mathbf{G}_5] + 2q_e^2 \cdot \text{Adv}_{\mathcal{S}, \text{KEM}}^{\text{IND-CCA}}(1^\kappa)$$

for some adversary $\mathcal{B}$. Now, in honest Alice-Bob interactions, the key $\bar{K}$ is entirely independent of the communication transcript.

Randomizing the Simulation ($\mathbf{G}_6$ - $\mathbf{G}_{10}$):

Sofar, the exchanged messages between Alice and Bob in honest sessions should already be distributed independently of the password π of both parties: Alice sends a random seed string and Bob responds with a ciphertext computed under a fresh public key. It remains to look into sessions where (a) Alice is malicious and interacts with an honest Bob-session, and (b) Bob is malicious but communicates with an honest Alice-session. Therefore, we aim at randomizing messages in response to adversarial query, which may be malicious and/or containing a trivial correct password guess. Here, we consider two *bad* events the simulation cannot prevent. The first one corresponds to the case where an adversary $\mathcal{A}$ forwards a pair $(z, \mathbf{b})$ that contains a correct password guess on z . Due to our inability

to extract $\mathcal{A}$'s guess, this event is also not detectable. However, we intuitively argue that an adversary who guessed the password correctly would be able to distinguish between messages created by honest instances and ones randomized by the simulation. Here, we rely on A-SEC-CCA to show that $\mathcal{A}$'s view on a pk used by an honest instance for encapsulating a key is indistinguishable from random. Therefore, we continue the simulation of the protocol and derive that $\mathcal{A}$'s advantage is bound to a factor of the number of queried sessions and random guessing over the password dictionary size $|\mathcal{D}|$. The second event corresponds to a **Corrupt** query placed by an adversary on connected honest instances.

Game $\mathbf{G}_6$ (Randomize C_b). Alter Game $\mathbf{G}_5$ by letting an honest Bob-session receiving $(z, \mathbf{b})$ which has not been created by an honest Alice-session use $C_{b,\text{sim}}$ instead of ciphertext C_b , where $(C_{b,\text{sim}}, \overline{K}'_{\text{sim}}) \leftarrow \text{KEM.Encap}_{\mathbf{A}_{\text{sim}}}(pk)$ for an independently sampled $\mathbf{A}_{\text{sim}}$. The honest Bob-session also uses the key $\overline{K}'$ for further steps. We claim that this modification is indistinguishable according to A-SEC-CCA. It then follows via a reduction $\mathcal{B}_2$ to A-SEC-CCA simulating the entire game $\mathbf{G}_6$ and injecting the challenge $\mathbf{A}$ -parts $(\mathbf{A}_0, \mathbf{A}_1)$ for the received $\mathbf{b}$ from the A-SEC-CCA game into the Alice-session, using $\mathbf{A}_0$ as $\mathbf{A}_a$ resp. using $\mathbf{A}_1$ as $\mathbf{A}_{\text{sim}}$ in the Bob-session. Here, we lose the factor of ignoring trivial password guessing, as the Alice-session has an sk that actually decrypts under an encapsulation invoked by the $\mathbf{A}$ -part obtained from the correct password. By doing so, an Alice-session cannot decapsulate the randomized ciphertext $C_{b,\text{sim}}$, which in turn does not reveal the randomized key $\overline{K}'_{\text{sim}}$, as KEM.Decap rejects implicitly by outputting a random key. On the other hand, the A-SEC-CCA game does not reveal the $\mathbf{A}$ -part used for the encapsulation. The reduction against $\mathbf{A}$ -Part Secrecy outputs 1 if and only if adversary $\mathcal{A}$ wins the simulated game. Hence, if the pair (C^*, K^*) in the $\mathbf{A}$ -Part Secrecy game is created under the public key with $\mathbf{A}_0$, then the simulation corresponds perfectly to game $\mathbf{G}_5$. If (C^*, K^*) is created under the public key with $\mathbf{A}_1$, then the simulation corresponds to this game. It follows

$$\Pr[\mathbf{G}_5] \leq \Pr[\mathbf{G}_6] + 2q_s^2 \cdot \text{Adv}_{\mathcal{B}_2, \text{KEM}}^{\text{A-SEC-CCA}}(1^\kappa) \cdot |\mathcal{D}|^{-1}$$

for some adversary $\mathcal{B}_2$, where we lose a factor 2 for switching from a left-or-right game A-SEC-CCA to the comparison between games $\mathbf{G}_5$ and $\mathbf{G}_6$. Note that a **Reveal** query on an honest Bob-session does not carry any significance in this scenario, since $\mathcal{A}$ cannot decapsulate $C_{b,\text{sim}}$, and did not guess the correct password. Thus they cannot compare Bob's key $\overline{K}'$ to a meaningful value.

Game $\mathbf{G}_7$ (Corrupt Bob). Declare the adversary to lose, if an honest Bob-session is marked *unfresh* after receiving $(z, \mathbf{b})$ which has not been created by a connected honest Alice-session. This game simulates the case where $\mathcal{A}$ obtains the password through *corrupting* an honest Bob instance in a protocol session. We define an *unbounded adversary*, whose interaction in this step does not affect the previous advantage. Thus, this game change is conceptual, and does not affect the security bound of the protocol. Recall that no test query can be placed by

$\mathcal{A}$ on *unfresh* sessions as per the security model. Although an honest Bob would have otherwise unknowingly generated a ciphertext C_b based on $(z, \mathbf{b})$ and their honest password, obtaining this password via corruption will not aid $\mathcal{A}$ in decapsulating a ciphertext $C_{b,\text{sim}}$ with a non-matching $(sk, (\mathbf{A}_{\text{sim}}, \mathbf{b}))$ pair. That is since the ciphertext is simulated using an independently sampled $\mathbf{A}_{\text{sim}}$ as per $\mathbf{G}_6$, and we had hence already accounted for the adversarial advantage stemming from A-SEC-CCA. This is justified through observing that $\mathcal{A}$'s advantage in $\mathbf{G}_6$ is bounded by the reduction to A-SEC-CCA and a multiplicative factor of guessing the attacked session over the password dictionary size. Thus, restricting $\mathcal{A}$'s interaction to a specific and known session (marked unfresh), eliminates the factors in the previous advantage term. Consequently, the adversary interacts with a single instance of the A-SEC-CCA experiment. It follows that $\Pr[\mathbf{G}_6] = \Pr[\mathbf{G}_7]$.

Game $\mathbf{G}_8$ (Randomize z). Change Game $\mathbf{G}_6$ by letting an honest Alice-session initiating the protocol use a randomly generated z_{sim} instead of an honestly masked seed ρ . Since we already accounted for collisions on z in game $\mathbf{G}_2$, we claim that this modification is indistinguishable according to SPLIT-PKU that an adversary $\mathcal{A}$ cannot distinguish between $\mathbf{A}$ -parts resulting from splitting pk_a and ones embedded within the $\mathbf{b}$ -part of the same public key. It then follows via a simple reduction $\mathcal{B}_3$ to SPLIT-PKU simulating game $\mathbf{G}_8$ and injecting the challenge $\mathbf{A}$ -part $\mathbf{A}_1$ for the received $\mathbf{b}$ -part from the SPLIT-PKU security game into the Bob-session. Here as well, we lose a factor for ignoring trivial password guessing over the password dictionary size. It follows

$$\Pr[\mathbf{G}_7] \leq \Pr[\mathbf{G}_8] + 2q_s^2 \cdot \text{Adv}_{\mathcal{B}_3, \text{KEM}}^{\text{SPLIT-PKU}}(1^\kappa) \cdot |\mathcal{D}|^{-1}$$

for some adversary $\mathcal{B}_3$, where we lose a factor 2 for switching from a left-or-right game SPLIT-PKU to the comparison between games $\mathbf{G}_6$ and $\mathbf{G}_8$.

Game $\mathbf{G}_9$ (Randomize pk_a). Change Game $\mathbf{G}_8$ by letting an honest Alice-session initiating the protocol use a randomly generated key pair $(sk_{\text{sim}}, pk_{\text{sim}})$ instead of an honestly generated one, where $(\mathbf{b}_{\text{sim}}, \rho_{\text{sim}}) \leftarrow pk_{\text{sim}}$ and an independently generated z_{sim} from $\mathbf{G}_8$. Upon receiving a response from a Bob-session, the Alice-session uses the previously randomized key pair to invoke KEM.Decap. Since $\mathcal{A}$ encapsulated their own key $K_{\mathcal{A}}$ into $C_{\mathcal{A}}$, it will not match the decapsulated key $\bar{K}$ for an Alice-Session. This change is indistinguishable for $\mathcal{A}$ according to the collision freeness of KEM (except for the case of a **Reveal** query addressed in $\mathbf{G}_{11}$). It then follows via a reduction $\mathcal{B}_4$ to A-CFR-CCA simulating game $\mathbf{G}_9$ and injecting the challenge $\mathbf{A}$ -parts $(\mathbf{A}_0, \mathbf{A}_1)$ for the received public keys from the A-CFR-CCA game into the session using $\mathbf{A}_0$ as $\mathbf{A}_a$ resp. using $\mathbf{A}_1$ as $\mathbf{A}_{\text{sim}}$. Note that we don't lose a factor for trivial password guessing, as we already accounted for it in game $\mathbf{G}_8$. However, we still lose a factor q_s for guessing the correct session. The reduction against A-CFR-CCA outputs 1 if and only if $\mathcal{A}$ wins the simulated game. Hence, if the pair (C^*, K^*) in the A-CFR-CCA game is created under the public key with $\mathbf{A}_0$, then the simulation corresponds to game $\mathbf{G}_8$. If (C^*, K^*) is created under the public key with $\mathbf{A}_1$, then the simulation corresponds to this game. We derive

$$\Pr[\mathbf{G}_8] \leq \Pr[\mathbf{G}_9] + 2q_s^2 \cdot \text{Adv}_{\mathcal{B}_4, \text{KEM}}^{\text{A-CFR-CCA}}(1^\kappa)$$

Game $\mathbf{G}_{10}$ (Corrupt Alice). Declare the adversary to lose, if an honest Alice-session is marked *unfresh* after sending $(z, \mathbf{b})$ to a Bob-Session. This game simulates the case where an adversary $\mathcal{A}$ obtains the password through *corrupting* an honest Alice instances in a protocol session. As in $\mathbf{G}_7$, we define an *unbounded adversary*, whose interaction in this step does not affect the previous advantage. Thus, this game change is conceptual, and does not affect the security bound of the protocol. Similarly, we first recall that no test query can be placed by $\mathcal{A}$ on *unfresh* sessions as per the security model. Second, although an honest Alice would have otherwise sent a z that indeed reveals the correct seed for sampling the honest **A**-part in her pk , and thus allowing $\mathcal{A}$ to generate a valid ciphertext that normally decapsualtes the same key for both users, obtaining the correct password via a corruption will not aid $\mathcal{A}$ in obtaining an identical key K^* with a non-matching (pk_a) . That is since Alice's pk and her masked seed z are simulated using independently sampled values as per $\mathbf{G}_8$ and $\mathbf{G}_9$, we had already ruled out trivial password guesses on z , $\mathcal{A}$ commits to a single (non-adaptive) response $C_{\mathcal{A}}$, and we have already accounted for the adversarial advantage stemming from both SPLIT-PKU and A-CFR-CCA respectively. This is justified through observing that $\mathcal{A}$'s advantage in $\mathbf{G}_8$ and $\mathbf{G}_9$ is bounded by the respective reductions and a multiplicative factor for guessing the attacked session (and the password dictionary size in $\mathbf{G}_8$). Thus restricting $\mathcal{A}$'s interaction to a specific and known session (marked unfresh) eliminates the factors in the previous advantage terms. Consequently, the adversary interacts with a single instance of SPLIT-PKU and A-CFR-CCA. It follows that $\Pr[\mathbf{G}_9] = \Pr[\mathbf{G}_{10}]$.

Randomizing Session Keys ($\mathbf{G}_{11}$):

We showed that the remaining sessions should either be unfresh and cannot be tested, or if the sessions are fresh, then they must have already been replaced by some independent data on the network. It now remains to randomize the final sessions keys such that they yield values indistinguishable from real keys.

Game $\mathbf{G}_{11}$ (Randomize K). Finally, we replace the final session key with a key chosen independently at random from the key space $\mathcal{K}$. That is, on all connected instances and for all **Execute** and **Send** queries, rendering the keys independent of all previous messages and the password. We claim that this change is indistinguishable from games $\mathbf{G}_1$ through $\mathbf{G}_{10}$ for $\mathcal{A}$. In other words, a **Test** query may be placed by $\mathcal{A}$ at any point of the simulation (except on *unfresh* instances), and the tested key will always be indistinguishable based on the key security of KEM. Hence, the adversary's advantage is negligible and bounded by IND-CCA security of the KEM and the number of placed queries. It follows

$$\Pr[\mathbf{G}_{10}] \leq \Pr[\mathbf{G}_{11}] + 2q_s^2 \cdot \text{Adv}_{\mathcal{S}, \text{KEM}}^{\text{IND-CCA}}(1^\kappa)$$

Where $\mathcal{S}$ is some adversary playing the indistinguishability game of KEM. Note that **Reveal** queries on Alice do not need to be explicitly handled by the simula-

tion. Since the used KEM is implicitly rejecting, decapsulating on honest values will always yield a valid key $K^* \in \mathcal{K}$ that is with negligible probability bound to the key space size indistinguishable from a real key (covered by IND-CCA). Having randomized all values involved in encapsulating and decapsulating a session key over the network, and since a **Test** query is rendered unavailable for an *unfresh* instance, $\mathcal{A}$'s view on honest keys as well as their own key is dependent only on their password guess being trivially correct (handled previously); and is indistinguishable from the randomization within the simulation.

Putting It All Together. Finally, all keys returned via a **Test** query are random values independent from the protocol simulation. Thus, an adversary cannot distinguish real keys from random ones. Their advantage is therefore upper-bounded by $\frac{1}{2}$ and the numbers of protocol executions, and the overall advantage by $\frac{1}{2}$ plus any losses collected throughout the games, giving Theorem 6.

6 Remarks on Concrete Instantiations

We note that App. C.2 and App.C.3 contain basics on some of the arguments and parameter choices we present in the following.

6.1 Remarks on Ciphertext Validation

To exemplify ciphertext validation, we first recall that an LWE KEM ciphertext consists of the two components $(\mathbf{u}, \mathbf{v})$ as previously illustrated in Fig. 5, and that the decapsulation internally invokes a decryption routine to obtain the encrypted message $m = \text{decode}(\mathbf{v} - \mathbf{s}^T \mathbf{u})$, e.g., in Kyber. We ignore the decoding step for simplicity and write for a modulus q and a decryption threshold $q/4$:

$$\begin{aligned} m &= \mathbf{b}^T \mathbf{r} + e_2 + \lceil q/2 \rceil \cdot m - \mathbf{s}^T (\mathbf{A}^T \mathbf{r} + \mathbf{e}_1) \\ &= \mathbf{r}^T (\mathbf{A}^T \mathbf{s} + \mathbf{e}) + e_2 + \lceil q/2 \rceil \cdot m - \mathbf{s}^T (\mathbf{A}^T \mathbf{r} + \mathbf{e}_1) \\ &= \mathbf{r}^T \mathbf{A}^T \mathbf{s} + \mathbf{e}^T \mathbf{r} + e_2 + \lceil q/2 \rceil \cdot m - \mathbf{r}^T \mathbf{A}^T \mathbf{s} - \mathbf{e}_1^T \mathbf{s} \\ &= \lceil q/2 \rceil \cdot m + \underbrace{\mathbf{e}^T \mathbf{r} + e_2 - \mathbf{e}_1^T \mathbf{s}}_{\text{small values} \leq q/4} \end{aligned}$$

Since the term $\mathbf{r}^T \mathbf{A}^T \mathbf{s}$ cancels out in the equation above, all that is left are the message m and a combination of error terms. Let this combination be ω . In order for LWE decryption and its variants to work, ω must be bounded by some β s.t. $\omega \in [2\alpha\beta^2 + \beta]$, where α is the number of samples (i.e, rows) in $\mathbf{A}$; and for any ω it must hold that $[2\alpha\beta^2 + \beta] < q/4$. Hence, each bit in $m \in \{0, 1\}^{|m|}$ decodes depending on the remaining errors. That is, if they are closer to 0 or to $q/2$ [54]. Consequently, if $\mathbf{v}$ in the ciphertext was already below this threshold, one could trivially decode the message without knowledge of the secret key. On the other hand, if $\mathbf{u}$ was equal to 0, the secret key is again no longer needed, and $\mathbf{v}$ will always decode to the same message m .

Attack on NICE-PAKE. Now, consider a malicious Alice whose goal is to either guess Bob’s password, or trick them into accepting the same final session key. Since Alice has complete control over the **b**-part, she can craft it anyway she wants. While the A-SEC-CCA property allows us to bound the advantage of Alice in distinguishing the **A**-part for a given **b**-part, it also means that the Alice has implicit access to a decryption oracle that accepts queries on the challenge ciphertext when the **A**-parts match. That is, since she already knows the secret to her own public key. Similarly, a malicious Bob aims at tricking Alice by forwarding a malicious ciphertext that bypasses A-CFR-CCA and decapsualte into the same key under different encapsulation public keys. If a malicious Alice forwards a small norm **b**-part (e.g., generated without a secret), any honest ciphertext can be trivially and correctly decapsualted by Alice, regardless of the **A**-part used by Bob in the encapsualtion. Analogously, if a malicious Bob forwards a ciphertexts that discards the component containing the **A**-part and the ecnapsulation randomness, the decapsulation will proceed independent of Alice’s secret key. Hence, we observe that KEM security properties only cover malicious public keys or ciphertexts that were generated using some valid secret key in the key generation, or some valid secret randomness in the encapsulation.

Ciphertext validation. As it would be futile to try to capture all the edge cases on the **b**-part level (as discussed in the following sections), we observe that we only need to detect invalid values for which our new KEM properties cannot be applied. Hence, we sketch a general method to validate the KEM ciphertext inspired by the recent and ongoing work on defining new KEM validation methods other than the standard FO re-encryption step [55,56].

Definition 18 (KEM Ciphertext validation oracle KCVO). *For a given LS-KEM with public key space $\mathcal{PK}$, ciphertext space $\mathcal{C}$, and output key space $\mathcal{K}$, we define the ciphertext validation oracle illustrated in Fig. 9 as $\text{KCVO}(pk, C, K)$, where KCVO takes as input a public key pk , a ciphertext C and an output key K , and returns a bit.*

$\text{KCVO}(pk, C, K)$	$\text{TrivDecap}(pk, C)$
1: $K' = \text{TrivDecap}(pk, C)$	1: $\mathbf{v} \leftarrow C$
2: if $K = K'$	2: $m' \leftarrow \text{PKE.decode}(\mathbf{v})$
3: return 0	3: $k' \leftarrow G_2(G_1(pk), m')$
4: else return 1	4: $K' \leftarrow F(k', C)$
	5: return K'

Fig. 9. LS-KEM ciphertext validation oracle KCVO and its internal function TrivDecap utilizing the hash functions F , G_2 and G_1 as defined in Fig. 3.

The KCVO internally uses a function TrivDecap (Fig. 9), which attempts to trivially decapsualte the challenge ciphertext without a secret key. The oracle checks if the key returned by TrivDecap matches its input and outputs 0 signaling an invalid ciphertext, otherwise 1. It is relatively obvious that TrivDecap can

for instance be instantiated using the internal `decode` function of a KEM PKE combined with the transform used to derive the output key (e.g., the T transform in $\text{FO}_m^{\mathcal{L}}$). Other options may be found in performing a range check on the value $\mathbf{v}$, asserting for example if $\mathbf{v} \in \mathbb{Z}_q$ (in RLWE and MLWE this corresponds to $\mathbf{v} \in R_q$). Nevertheless, we leave proving KCVO and `TrivDecap`, and defining concrete bounds for their correctness for future work.

6.2 Remarks on the Concrete Value of $\varepsilon_{\text{whLWE}}$ in Theorem 4

There are two incomparable reductions for Extended LWE applicable to our use-case: one from O’Neill et al. in [57] that yields a $(1/q)$ multiplicative advantage loss per application, and one from Brakerski et al. [58] that yields a negligible advantage loss, up to a mild change in parameters. In the first case [57], we cannot afford to iterate a reduction with $(1/q)$ multiplicative loss over a column of v in FrodoKEM (that is an 8×8 matrix) for a total multiplicative loss of at least $(1/8q^8)$, as this would give concrete loss of bits of security at least $3 \cdot 16 \cdot 8 = 384$. In the second case [58], we do not see (currently) how to prove the analogue of their Claim 4.6: that is, constructing an unimodular $\mathbf{U}$ (with small largest singular value) so that removing $\mathbf{U}$ ’s left column yields that all the remaining columns are orthogonal to an arbitrary element of $\mathbb{Z}_q^k$. If such $\mathbf{U}$ can be demonstrated, this would provide an alternative, concretely-effective proof of security. We also do not see how to easily use the “noise lossiness” techniques of Brakerski and Döttling [59], as we require decisional hardness, but their proof only guarantees search hardness in the case of a (non-prime) power-of-2 integer modulus q as in FrodoKEM. However, using the techniques of Cheon et al. [45,46] and Liu et al. [47], we can calculate a small loss in concrete bit-security for a FrodoKEM-instantiation as follows: Following Theorem 2, the noise and error distributions of FrodoKEM are identical, so we have $\sigma'_1 = \sigma'_2$. Then, $\sigma_1 = \sigma'_1/\sqrt{2} = \sigma'_2/\sqrt{2}$. Here, $k = 8$, so we have concrete security from Plain LWE, but with a $\sqrt{8} \cdot \sqrt{2} = 4$ multiplicative loss in variance. This yields that an instantiation of A-SEC-CCA security in our protocol from FrodoKEM-640 is as hard as if the variance were reduced from 2.8 to 0.7; or from FrodoKEM-1344 if the variance were reduced from 1.4 to 0.35. In the first case (Frodo-640), this is close to (but actually, slightly higher entropy) having a uniform $\{0, 1\}$ -valued marginal distribution of the secret key and error terms in the view of the adversary after leakage. In the second case, it’s slightly lower entropy than uniform-binary secrets and errors, but the additional dimension of FrodoKEM-1344 may make up for this. In general, it would be better to re-parameterize a FrodoKEM-style Plain LWE KEM (call it “GimliKEM”) with either slightly higher noise variance or slightly higher dimension (or both). One can consider such trade-offs in practice by using Albrecht et al.’s LWE Estimator tool [60] to find optimal choices.

6.3 A Complete Break of a Kyber-Instantiation

We describe three different (very efficient) attacks by a Malicious Alice against a Kyber-instantiation of the protocol, which result in either a major leakage on

or **complete recovery** of Bob’s ciphertext randomness $\mathbf{r}$ in any given Kyber session. In what follows, recall the concrete Kyber set-up. Let $R = \mathbb{Z}[X]/(X^{256} + 1)$ and $q = 3329$. Honest public keys are $(\mathbf{A}, \mathbf{b}) \in R_q^{k \times k} \times R_q^k$ for $k \in \{2, 3, 4\}$, where $\mathbf{A}$ is unrolled via G from a random seed $\rho_{\mathbf{A}}$ and so can be treated as having the uniform distribution over the coordinates of the Chinese Remainder Theorem (CRT) embedding, respectively the coefficient embedding, of each polynomial $\mathbf{A}_{i,j \in [k]} \in R_q$, and where $\mathbf{b} := \mathbf{A}\mathbf{s} + \mathbf{e}$ for $\mathbf{s}, \mathbf{e}$ drawn coefficient-wise from a binomial distribution η with parameter 2 (or parameter 3 for the secret $\mathbf{s}$ for Kyber-512) and thus having support in $\{-2, -1, 0, +1, +2\}$. Since $n = 256, q = 3329$, we have $n|(q-1)$ and so the ring R_q factors into $n/2$ distinct quadratic factors, meaning there is a CRT coordinate system defined that is isomorphic to $(\mathbb{Z}_q[X]/(X^2 + 1))^{n/2}$. Recall that $X^2 + 1$ is the 4th cyclotomic polynomial and that elements of the quadratic ring $\mathbb{Z}_q[X]/(X^2 + 1)$ are represented by two integers modulo q with slot-wise addition and simple, grade-school convolution-multiplication. One can map efficiently from the coefficient representation of polynomials in R_q to their CRT coordinate system and back using the Number Theoretic Transform (NTT) and inverse-NTT.

A first attack: When honest $\mathbf{A}$ contains “correlated” zero divisors. Recall that the protocol’s security proof contemplates hints to leak on the secret $\mathbf{r}$ of the challenge ciphertext’s MLWE secret in the form of v . To demonstrate that such hints “only reveal unstructured entropy,” we generically need that $\mathbf{A}$ is invertible, so that we can consider the expression $\mathbf{r} + \mathbf{A}^{-1}\mathbf{e}'$ when attempting to swap u to uniform in order to show anonymity. While FrodoKEM’s $\mathbf{A}$ -part is invertible except with negligible probability, this is not the case for Kyber. In particular, if there exists an CRT-coordinate index $z \in [n/2]$ and fixed column index $j \in [k]$ so that for all R_q polynomials $\mathbf{A}_{i,j}$ (i.e. for all row indices $i \in [k]$)

$$\begin{aligned} \text{we have that, } \text{NTT}(\mathbf{A}_{i,j})[z] &= 0 \in \mathbb{Z}_q[X]/(X^2 + 1) \\ \text{that is, } \text{CRT}(\mathbf{A}_{i,j})[z] &= (0, 0) \in (\mathbb{Z}_q)^2, \end{aligned}$$

then $\mathbf{A}$ is not invertible in $R_q^{k \times k}$. In this event, the leakage produced by the hint v is “unexpectedly” algebraically-structured and will convey information about $\mathbf{r}$ and $\mathbf{e}$ that is constrained to non-maximal ideals of the ring R_q . This event occurs with probability at least $\frac{k \cdot n/2}{q^{2 \cdot k}}$, which is noticeable since k is constant. For e.g., Kyber-1024 this event occurs with probability at least $\frac{4 \cdot 256/2}{3329^{2 \cdot 4}} \approx 2^{-84.6} \gg 2^{-256}$.

“Patching” the first attack: Check $\mathbf{A}$ -invertibility. A simple patch for this issue is for Honest Bob to attempt to invert any Kyber $\mathbf{A}$ before using it to construct his ciphertext in the protocol. While relatively efficient (if costing an undesirable practical slowdown), this especially has the downside of forcing the protocol to be “aware” of the particular lattice KEM being used.

A second attack: When Alice chooses $\mathbf{b}$ (resp. each $\mathbf{b}_i$) to be a unit in the ring R_q . A larger concern is if malicious Alice arbitrarily chooses $\mathbf{b}$ to be a “degenerate”

element of R_q , such as a unit – for example, $1 \in R_q$. In this case, $\mathbf{b}$ vanishes completely in the expression $v = \mathbf{b}\mathbf{r} + \mathbf{e}''$, resulting in the hint $v = \sum_{i \in [k]} \mathbf{r}_i + \mathbf{e}''_i$, which dangerously exposes much of the entropy in $\mathbf{r}$ and $\mathbf{e}''$.

“Patching” the second attack: Check if $\mathbf{b}$ is a unit (per slot). Before Honest Bob constructs a ciphertext, he can test if elements of $\mathbf{b}$ are units in R_q with a straightforward calculation. However, concern should continue growing: How many bad cases could there be? When have you caught them all?

A third attack: When Alice chooses $\mathbf{b}$ to be a “gadget vector” with moderately-sized radix. Finally, consider when Malicious Alice chooses $\mathbf{b}$ to be a non-unit scalar. This is simplest to see in the Ring-LWE (i.e., rank 1) “case,” when $\mathbf{b}, \mathbf{r}$, and $\mathbf{e}''$ are all simply polynomials in R_q . Since the support of each coefficient of $\mathbf{b}$ and $\mathbf{e}''$ are very small – e.g. in $\{-2, -1, 0, +1, +2\}$ – and the modulus $q = 3329$ is relatively large by comparison, consider if $\mathbf{b}$ is chosen as (say) $64 \in R_q$. Then, the hint $v = 64\mathbf{r} + \mathbf{e}''$, and the coefficients of $\mathbf{r}$ and $\mathbf{e}''$ can be read, directly, from the bit representation of the coefficients of v . In the case of Kyber-1024, Alice can choose $\mathbf{b}$ as a “gadget vector” such as $(4, 4^2, 4^3, 4^4) = (4, 16, 64, 256) \in R_{3329}^4$. Then, even with the vector-wise addition over rank 4, each of the coordinates of each of the $\mathbf{r}_i$ can still be read off directly from the bit representation of v , independent of $\mathbf{e}''$ – this is a complete break.

6.4 (Speculatively) Tweaking Kyber to Achieve A-SEC-CCA

Intuitively, the failure of A-SEC-CCA security for Kyber is due to the existence of many choices of $\mathbf{b} \in R_q^k$ such that computing the term $v = \mathbf{b}\mathbf{r} + \mathbf{e}''$, for $\mathbf{r}$ and $\mathbf{e}''$ supported on a small range like $[-2, +2]$, is *very far* from inducing wrap-around in the arithmetic modulo q . When reduction modulo q does not occur, then releasing an R_q -element as a hint can completely determine the secret values $(\mathbf{r}, \mathbf{e}'')$ of $\mathbf{b}\mathbf{r} + \mathbf{e}''$. Alternatively, if (sufficient) wrap-around modulo q occurs when computing $\mathbf{b}\mathbf{r} + \mathbf{e}''$, such an R_q -element cannot – “on its own” – convey the full entropy that went into the sampling of $(\mathbf{r} = (\mathbf{r}_1, \dots, \mathbf{r}_k); \mathbf{e}'' = (\mathbf{e}''_1, \dots, \mathbf{e}''_k)) \in R_q^k \times R_q^k$. Of course, in the algebraically-structured case, one not only needs to ensure reduction modulo q , but also that there is no special algebraic structure (e.g., confinement of the arithmetic to non-maximal ideals) that can be adversarially abused. For the sake of the science, we *speculate* that changing the distribution of Kyber (respectively: Module-LWE with rank $k \geq 2$ or preferably even higher rank) to use much larger supports and much higher entropy distributions for $\mathbf{r}$ and $\mathbf{e}''$ (as well as for $\mathbf{e}'$ in the u -part of the ciphertext, etc.) might lead to a A-SEC-CCA-secure implementation. Concretely, to ensure that the arithmetic in each coordinate wraps around modulo q for every non-adaptive choice of (not easily rejection-samplable) $\mathbf{b}$ that would otherwise “separate the coordinates” as in our gadget-based attack, it seems one needs to sample secret and error coordinates with weight at least up to $\approx \pm\sqrt{q}$, or around $\{-60, \dots, +60\}$ for Kyber’s modulus $q = 3329$. Note that this is a requirement of *larger secrets*

than the asymptotically-suggested $\approx \sqrt{n}$ magnitude given by traditional security theorems in the literature [61]. The reason for this is that the typical Hermite Normal Form style of proof (that one can use the (M)LWE error distribution for the secret) inherently leverages that (M)LWE samples are built from uniform $\mathbf{A}$, which is not our case here. We emphasize that we have no security proof for this idea. In fact – we lack a theory for how to prove its security. While Plain LWE is known to be fairly robust against leakage [62,59] due to being able to use a leftover hash lemma argument that “plays with the dimension,” proving a practically useful form of entropic security for algebraically-structured lattice cryptography is notoriously difficult [63,64]. We re-highlight this gap in the theory as an interesting open problem area, especially when considering practical instantiations similar to Kyber, which we leave for future research.

7 Conclusion

In this work, we addressed the issues accompanying quantum-resistant PAKE designs and constructions from lattice-based PAC KEMs and ideal ciphers. We presented our PAKE construction **NICE-PAKE**, which eliminates the usage of an IC in the public key authentication step through masking (XOR-ing) a purely uniform part of the splittable key in LWE KEMs. Our security proof relies on standard KEM properties and assumptions, as well as newly introduced ones (A-SEC-CCA, A-CFR-CCA, SPLIT-PKU). However, our construction indeed suffers from the lack of existence of standard LWE and MLWE KEMs, with which NICE-PAKE can be directly instantiated. To overcome this issue, we presented a discussion on concrete modifications for LWE Frodo-style and possible tweaks for MLWE Kyber-style KEMs.

The development and proof of **NICE-PAKE** has shed new light on the possibility of replacing troublesome idealized objects (i.e., the IC) in PAKE designs. Most importantly, we are now confident that the IC can be completely eliminated. Our work has indicated the precise properties needed for lattice-based KEMs in PAKEs, opening the door for dedicated constructions. Eliminating the IC highlighted the fact that neither uniform nor non-uniform public keys are per se favorable for building PAKEs. Both come with a respective (specific) security issue, that is idealized away by IC. From our perspective, FrodoKEM remarkably showed its strength being built from unstructured lattices and standard plain LWE assumptions.

A number of open questions remain. The first is to investigate the consequences of adjusting the variance value in FrodoKEM’s error distribution, both for the core security and the performance of the scheme. The same goes also for Kyber/ML-KEM, where we suggest that using larger supports and higher entropy in the encapsulator’s secrets could lead to secure splittable key applications. A similar question arises regarding the concrete overall security and performance, should such adjustments be taken. Regarding the usage of KEMs

for protocol design, and disregarding size and performance differences, we found that there are major differences regarding the effective remaining security of different LWE-based KEMs in protocol contexts; i.e., the loss of bits of security under the different KEM properties (such as A-SEC-CCA) in the security proof substantially varies between the schemes. We deem deeper research on the security effects of swapping KEMs in higher level cryptographic constructions (such as PAKEs) an important future work. Observing the ongoing interest in purely generic KEM-based PAKE designs, it is also worth investigating whether our first attempt **Simple NICE PAKE** (cf. Sec. 2) could actually be achieved with a formal analysis based only on inherent KEM properties.

In order to do so, we suggest tackling properties directly aimed at the security of KEM public keys, such that some structured keys are statically far from uniform, yet still computationally close to uniform. However, and to the best of our knowledge, the only key property addressed so far in the literature concerns mainly the uniformity of keys. An interesting approach is to consider utilizing Threshold Secret Sharing schemes built from the same primitives as the KEMs, so that destroying the structure of the keys through “encryption” can be eliminated.

Acknowledgment

We thank Marc Fischlin, Hart Montgomery, Scott Simon, Jonathan Katz, Jintai Ding, Shuichi Katsumata, Johannes Ottenhues, Marcel Tiptet and Timm Lauser for useful discussions. This research work has been partly funded by the German Federal Ministry of Education and Research and the Hessian State Ministry for Higher Education, Research and the Arts within their joint support of the National Research Center for Applied Cybersecurity ATHENE. Daniel Apon’s affiliation with The MITRE Corporation is provided for identification purposes only, and is not intended to convey or imply MITRE’s concurrence with, or support for, the positions, opinions, or viewpoints expressed by the author. This work was supported in part by the MITRE Independent Research and Development Program. Approved for Public Release. Distribution Unlimited. Case Number 24-3386.

References

1. F. Hao and P. C. van Oorschot, “Sok: Password-authenticated key exchange – theory, practice, standardization and real-world lessons,” ser. ASIA CCS ’22. Association for Computing Machinery, 2022.
2. Bellovin, S.M. and Merritt, M., “Encrypted key exchange: password-based protocols secure against dictionary attacks,” in *Proceedings 1992 IEEE Computer Society Symposium on Research in Security and Privacy*, 1992.
3. I. McQuoid, M. Rosulek, and L. Roy, “Minimal symmetric pake and 1-out-of-n ot from programmable-once public functions,” in *Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security*, 2020.

4. H. Beguin, C. Chevalier, D. Pointcheval, T. Ricosset, and M. Rossi, “Get a cake: Generic transformations from key encapsulation mechanisms to password authenticated key exchanges,” in *ACNS 2023, Kyoto, Japan, June 19–22, 2023, Proceedings, Part II*. Springer-Verlag, 2023.
5. J. Pan and R. Zeng, “A generic construction of tightly secure password-based authenticated key exchange,” in *Advances in Cryptology – ASIACRYPT 2023*. Singapore: Springer Nature Singapore, 2023.
6. N. Alnahawi, K. Hövelmanns, A. Hülsing, and S. Ritsch, “Towards post-quantum secure pake - a tight security proof for oake in the bpr model,” in *Cryptology and Network Security*. Springer Nature Singapore, 2024.
7. B. F. D. Santos, Y. Gu, and S. Jarecki, “Randomized half-ideal cipher on groups with applications to uc (a) pake,” in *Annual International Conference on the Theory and Applications of Cryptographic Techniques*. Springer, 2023.
8. J. Januzelli, L. Roy, and J. Xu, “Under what conditions is encrypted key exchange actually secure?” Cryptology ePrint Archive, Paper 2024/324, 2024.
9. A. Arriaga, M. Barbosa, S. Jarecki, and M. Škrobot, “C’est très chic: A compact password-authenticated key exchange from lattice-based kem,” Springer, 2025.
10. A. Arriaga, M. Barbosa, and S. Jarecki, “NoIC: PAKE from KEM without ideal ciphers,” Cryptology ePrint Archive, Paper 2025/231, 2025.
11. K. Hövelmanns, A. Hülsing, M. Kudinov, and S. Ritsch, “CAKE requires programming - on the provable post-quantum security of (o)CAKE,” Cryptology ePrint Archive, Paper 2025/458, 2025.
12. J. Black, “The ideal-cipher model, revisited: An uninstantiable blockcipher-based hash function,” in *Fast Software Encryption: FSE 2006, Graz, Austria, March 15–17, 2006, Revised Selected Papers 13*. Springer, 2006.
13. J. Hesse and M. Rosenberg, “PAKE combiners and efficient post-quantum instantiations,” Cryptology ePrint Archive, Paper 2024/1621, 2024.
14. Y. Dodis, D. Jost, S. Katsumata, T. Prest, and R. Schmidt, “Triple ratchet: A bandwidth efficient hybrid-secure signal protocol,” Cryptology ePrint Archive, 2025/078.
15. Bellare, Mihir and Pointcheval, David and Rogaway, Phillip, “Authenticated Key Exchange Secure against Dictionary Attacks,” in *Advances in Cryptology – EUROCRYPT 2000*. Springer Berlin Heidelberg, 2000.
16. M. Abdalla, M. Barbosa, T. Bradley, S. Jarecki, J. Katz, and J. Xu, “Universally composable relaxed password authenticated key exchange,” in *Annual International Cryptology Conference*. Springer, 2020.
17. S. Hanai, K. Tanaka, M. Tezuka, and Y. Yoshida, “Universally composable relaxed asymmetric password-authenticated key exchange,” in *International Conference on Security and Cryptography for Networks*. Springer, 2024.
18. J. Hesse, “Separating symmetric and asymmetric password-authenticated key exchange,” in *International Conference on Security and Cryptography for Networks*. Springer, 2020.
19. I. McQuoid and J. Xu, “An efficient strong asymmetric pake compiler instantiable from group actions,” in *International Conference on the Theory and Application of Cryptology and Information Security*. Springer, 2023.
20. Y. Lyu, S. Liu, and S. Han, “Efficient asymmetric pake compiler from kem and ae,” in *International Conference on the Theory and Application of Cryptology and Information Security*. Springer, 2025.
21. N. Alnahawi, D. Haas, E. Mauß, and A. Wiesmaier, “SoK: PQC PAKEs - cryptographic primitives, design and security,” Cryptology ePrint Archive, 2025/119.

22. V. Maram and K. Xagawa, "Post-quantum anonymity of kyber," in *IACR International Conference on Public-Key Cryptography*. Springer, 2023.
23. Katz, Jonathan and Vaikuntanathan, Vinod, "Smooth Projective Hashing and Password-Based Authenticated Key Exchange from Lattices," in *Advances in Cryptology – ASIACRYPT 2009*. Springer Berlin Heidelberg, 2009.
24. Ding, Jintai and Alsayigh, Saed and Lancrenon, Jean and Rv, Saraswathy and Snook, Michael, "Provably Secure Password Authenticated Key Exchange Based on RLWE for the Post-Quantum World," in *Topics in Cryptology – CT-RSA 2017*. Springer International Publishing, 2017.
25. Tang, Yongli and Li, Ying and Zhao, Zongqu and Zhang, Jing and Ren, Lina and Li, Yuanhong, "Improved Verifier-Based Three-Party Password-Authenticated Key Exchange Protocol from Ideal Lattices," *Security and Communication Networks*, 2021, publisher: Hindawi.
26. Wang, Jinhua and Chen, Ting and Liu, Yanyan and Zhou, Yu and Dong, XinFeng, "Efficient Two-Party Authentication Key Agreement Protocol Using Reconciliation Mechanism from Lattice," in *International Conference on Security and Privacy in New Computing Environments*. Springer, 2022.
27. S. Guo, Y. Song, S. Guo, Y. Yang, and S. Song, "Three-party password authentication and key exchange protocol based on mlwe," *Symmetry*, 2023.
28. Chaudhary, Dharminder and Kumar, Uddeshaya and Saleem, Kashif, "A Construction of Three Party Post Quantum Secure Authenticated Key Exchange Using Ring Learning with Errors and ECC Cryptography," *IEEE Access*, 2023.
29. Hongfeng Zhu and Xin Hao and Yang Sun, "Elliptic Curve Isogenies-Based Three-party Password Authenticated Key Agreement Scheme towards Quantum-Resistant," *J. Inf. Hiding Multim. Signal Process.*, 2014.
30. S. Terada and K. Yoneyama, "Password-based authenticated key exchange from standard isogeny assumptions," in *Provable Security*. Springer, 2019.
31. Abdalla, Michel and Eisenhofer, Thorsten and Kiltz, Eike and Kunzweiler, Sabrina and Riepel, Doreen, "Password-Authenticated Key Exchange from Group Actions," in *Advances in Cryptology – CRYPTO 2022*. Springer Nature Switzerland, 2022.
32. Y. Lyu, S. Liu, and S. Han, "Universal composable password authenticated key exchange for the post-quantum world," in *Annual International Conference on the Theory and Applications of Cryptographic Techniques*. Springer, 2024.
33. G. Alagic and A. Russell, "Quantum-secure symmetric-key cryptography based on hidden shifts," in *Annual international conference on the theory and applications of cryptographic techniques*. Springer, 2017.
34. A. Hosoyamada and K. Yasuda, "Building quantum-one-way functions from block ciphers: Davies-meyer and merkle-damgård constructions," in *Advances in Cryptology–ASIACRYPT 2018: Brisbane, QLD, Australia, December 2–6, 2018, Proceedings, Part I* 24. Springer, 2018.
35. S. Sato and J. Shikata, "So-cca secure pke in the quantum random oracle model or the quantum ideal cipher model," in *Cryptography and Coding: IMACC 2019, Oxford, UK, December 16–18, 2019, Proceedings* 17. Springer.
36. J. Czaikowski, C. Majenz, C. Schaffner, and S. Zur, "Quantum lazy sampling and game-playing proofs for quantum indistinguishability," *Cryptology ePrint Archive*, Paper 2019/428, 2019. [Online]. Available: <https://eprint.iacr.org/2019/428>
37. D. Unruh, "Compressed permutation oracles (and the collision-resistance of sponge/SHA3)," *Cryptology ePrint Archive*, Paper 2021/062, 2021. [Online]. Available: <https://eprint.iacr.org/2021/062>
38. A. Rosmanis, "Tight bounds for inverting permutations via compressed oracle arguments," *arXiv preprint arXiv:2103.08975*, 2021.

39. G. Alagic, C. Bai, A. Poremba, and K. Shi, “On the two-sided permutation inversion problem,” *arXiv preprint arXiv:2306.13729*, 2023.
40. D. Unruh, “Towards compressed permutation oracles,” in *Advances in Cryptology – ASIACRYPT 2023*. Springer.
41. C. Majenz, G. Malavolta, and M. Walter, “Permutation superposition oracles for quantum query lower bounds,” Cryptology ePrint Archive, Paper 2024/1140, 2024.
42. M. Zhandry, “How to record quantum queries, and applications to quantum indistinguishability,” in *Advances in Cryptology–CRYPTO 2019: Santa Barbara, CA, USA, August 18–22, 2019, Proceedings, Part II* 39. Springer, 2019.
43. M. Bellare and P. Rogaway, “Random oracles are practical: A paradigm for designing efficient protocols,” in *Proceedings of the 1st ACM Conference on Computer and Communications Security*, 1993.
44. D. Boneh, K. Lewi, H. Montgomery, and A. Raghunathan, “Key homomorphic prfs and their applications,” in *Advances in Cryptology – CRYPTO 2013*. Springer.
45. J. H. Cheon, D. Kim, D. Kim, J. Lee, J. Shin, and Y. Song, “Lattice-based secure biometric authentication for hamming distance,” in *Information Security and Privacy: 26th Australasian Conference, ACISP 2021, Virtual Event, December 1–3, 2021, Proceedings*. Springer-Verlag, 2021.
46. J. Lee, D. Kim, D. Kim, Y. Song, J. Shin, and J. H. Cheon, “Instant privacy-preserving biometric authentication for hamming distance,” Cryptology ePrint Archive, Paper 2018/1214, 2018.
47. Z. Liu, K. Sotiraki, E. Tromer, and Y. Wang, “Snake-eye resistance from LWE for oblivious message retrieval and robust encryption,” Cryptology ePrint Archive, Paper 2024/510, 2024.
48. C. Cremers, A. Dax, and N. Medinger, “Keeping up with the kems: Stronger security notions for kems and automated analysis of kem-based protocols,” 2024.
49. E. Fujisaki and T. Okamoto, “Secure integration of asymmetric and symmetric encryption schemes,” in *Annual international cryptology conference*. Springer, 1999.
50. —, “Secure integration of asymmetric and symmetric encryption schemes,” *Journal of cryptology*, 2013.
51. J. Bos, J. J. P. Ducas, L. E. Kiltz, E. Lepoint, T. Lyubashevsky, V. M. Schanck, J. M. Schwabe, P. Seiler, G. Stehle, D. Damien, “CRYSTALS - Kyber: A CCA-Secure Module-Lattice-Based KEM,” in *2018 IEEE European Symposium on Security and Privacy (EuroS&P)*. IEEE, 2018.
52. J. Bos, C. Costello, L. Ducas, I. Mironov, M. Naehrig, V. Nikolaenko, A. Raghunathan, and D. Stebila, “Frodo: Take off the ring! practical, quantum-secure key exchange from lwe,” in *Proceedings of the 2016 ACM SIGSAC conference on computer and communications security*, 2016.
53. P. Grubbs, V. Maram, and K. G. Paterson, “Anonymous, robust post-quantum public key encryption,” in *Advances in Cryptology – EUROCRYPT 2022: Trondheim, Norway, May 30 – June 3, 2022, Proceedings, Part III*. Springer-Verlag, 2022.
54. V. Lyubashevsky, “Basic lattice cryptography: The concepts behind kyber (ML-KEM) and dilithium (ML-DSA),” Cryptology ePrint Archive, Paper 2024/1287.
55. K. Hövelmanns and M. Kudinov, “Treating dishonest ciphertexts in post-quantum KEMs – explicit vs. implicit rejection in the FO transform,” Cryptology ePrint Archive, Paper 2025/062.

56. K. Hövelmanns, A. Hülsing, C. Majenz, and F. Sisinni, “(un)breakable curses - re-encryption in the fujisaki-okamoto transform,” Cryptology ePrint Archive, Paper 2025/299.
57. A. O’Neill, C. Peikert, and B. Waters, “Bi-deniable public-key encryption,” in *Advances in Cryptology–CRYPTO 2011: Santa Barbara, CA, USA, August 14–18, 2011. Proceedings 31*. Springer, 2011.
58. Z. Brakerski, A. Langlois, C. Peikert, O. Regev, and D. Stehlé, “Classical hardness of learning with errors,” ser. STOC ’13. New York: Association for Computing Machinery.
59. Z. Brakerski and N. Döttling, “Hardness of LWE on General Entropic Distributions,” in *Advances in Cryptology – EUROCRYPT 2020*. Springer International Publishing.
60. M. R. Albrecht, R. Player, and S. Scott, “On the concrete hardness of learning with errors,” Journal of Mathematical Cryptology. ISSN (Online) 1862-2984, ISSN (Print) 1862-2976 DOI: 10.1515/jmc-2015-0016, October 2015.
61. B. Applebaum, D. Cash, C. Peikert, and A. Sahai, “Fast cryptographic primitives and circular-secure encryption based on hard learning problems,” in *Advances in Cryptology - CRYPTO 2009*. Springer Berlin Heidelberg, 2009.
62. S. Goldwasser, Y. T. Kalai, C. Peikert, and V. Vaikuntanathan, “Robustness of the learning with errors assumption,” in *International Conference on Supercomputing*, 2010. [Online]. Available: <https://api.semanticscholar.org/CorpusID:6166048>
63. M. Bolboceanu, Z. Brakerski, R. Perlman, and D. Sharma, “Order-lwe and the hardness of ring-lwe with entropic secrets,” in *Advances in Cryptology – ASIACRYPT 2019*. Springer International Publishing.
64. F.-H. Liu and Z. Wang, “Rounding in the rings,” in *Advances in Cryptology – CRYPTO 2020*. Springer International Publishing, 2020.
65. P. Ravi, J. Howe, A. Chattopadhyay, and S. Bhasin, “Lattice-based key-sharing schemes: A survey,” *ACM Comput. Surv.*, 2021.
66. O. Regev, “Lattice-based cryptography,” in *Annual International Cryptology Conference*. Springer, 2006.
67. —, “The learning with errors problem,” *Invited survey in CCC*, 2010.
68. —, “On lattices, learning with errors, random linear codes, and cryptography,” ser. STOC ’05. Association for Computing Machinery, 2005.
69. V. Lyubashevsky, C. Peikert, and O. Regev, “On ideal lattices and learning with errors over rings,” in *Advances in Cryptology–EUROCRYPT 2010: French Riviera, May 30–June 3, 2010. Proceedings 29*. Springer, 2010.
70. Z. Brakerski, C. Gentry, and V. Vaikuntanathan, “(leveled) fully homomorphic encryption without bootstrapping,” *Transactions on Computation Theory*, 2014.
71. A. Langlois and D. Stehlé, “Worst-case to average-case reductions for module lattices,” *Designs, Codes and Cryptography*, 2015.
72. D. Apon, X. Fan, and F.-H. Liu, “Deniable attribute based encryption for branching programs from lwe,” in *TCC 2016-B, Beijing, China, October 31–November 3, 2016, Proceedings, Part II 14*. Springer, 2016.
73. J. Alperin-Sheriff and C. Peikert, “Circular and kdm security for identity-based encryption,” in *International Workshop on Public Key Cryptography*. Springer, 2012.
74. R. Canetti and Y. Chen, “Constraint-Hiding Constrained PRFs for NC¹ from LWE,” in *Advances in Cryptology – EUROCRYPT 2017*. Springer International Publishing.
75. J. Alperin-Sheriff and D. Apon, “Dimension-preserving reductions from LWE to LWR,” Cryptology ePrint Archive, Paper 2016/589, 2016.

A The Bellare-Pointcheval-Rogaway (BPR) Model

An adversary $\mathcal{A}$ is given a number of capabilities, or better said actions, called queries. $\mathcal{A}$ interacts with the protocol through these queries with so-called oracles that implement the protocol flow on behalf of honest parties called users (our friends *Alice* and *Bob*). $\mathcal{A}$ may assume any role they wish, i.e., either an active man-in-the-middle (malicious *Mallory*), or a passive connector forwarding messages between honest parties (eavesdropping *Eve*).

Sessions, Users, and Initialization. The game consists of an unlimited number of sessions between protocol instances. These sessions can be initiated by $\mathcal{A}$ in parallel or sequentially whenever they want. Each of these sessions chooses, upon initialization, two protocol instances $\mathcal{U}_i, \mathcal{V}_j$. Instances are users in a set $\mathcal{U}$ and can be viewed as initiators and receivers⁴. An initiator $\mathcal{U}_i$ is assigned their own unique password $\pi_{\mathcal{U}_i} \in \mathcal{D}$ that is also known to a receiver $\mathcal{V}_j$.

Termination, Accepting, and Partnering. An instance may terminate either in an accepting state (key agreement is successful), or with no output in the case of rejection (key agreement is unsuccessful). A terminated instance may refuse to participate further in a protocol session. Two instances are partnered if they both terminate in accepting state with the same session key. An instance can however be terminated or accepting without being partnered. That is if an instance is ready to use a session key, but does not necessarily have any accepting partner.

Adversarial Model. $\mathcal{A}$'s goal is to distinguish between real and random session keys. At any point, $\mathcal{A}$ choose one session to test, which then outputs a bit b (random challenge). $\mathcal{A}$ outputs another bit b' , and wins if they guessed correctly, i.e., if $b' = b$. We say that the adversary wins if on issuing a **Test** query for a user $\mathcal{U}_i$ that has terminated in accepting state (i.e. has a session key K) and no **Reveal** or **Corrupt** query has been issued to this user or any user partnered with them, $\mathcal{A}$ correctly guesses the bit selected in the **Test** query. Hence, the security here, same as in KEX security, lies within the ability of the protocol to guarantee the indistinguishability of honest session keys from random ones against any efficient adversary. $\mathcal{A}$ is given access to the following queries, and if necessary an oracle modeled as a RO for hash functions $\mathcal{H}$.

- **Execute**($\mathcal{U}_i, \mathcal{V}_j$): Execute an honest instance of the protocol that terminates in accepting state. $\mathcal{A}$ is given a full transcript of the execution (models eavesdropping).
- **Send**($\mathcal{U}_i, m$): Send a message to an honest user that causes them to proceed depending on their state (models impersonating attack)
- **Reveal**($\mathcal{U}_i$): Get the final session key for an accepting user, or the rejection symbol $\perp$ for a non-accepting user (models key leaking).
- **Corrupt**($\mathcal{U}_i$): Get the password $\pi_{\mathcal{U}_i}$ of a user in the weak-corruption model. In the strong-corruption model $\mathcal{A}$ may also view the internal state of the user (total break of an honest user).

⁴ This simplified description is sufficient for symmetric PAKEs.

- **Test**($\mathcal{U}_i$): Output a real or a random session key based on a bit flip made by the challenger. If a user is unfresh or not in accepting state, the test returns the rejection symbol $\perp$. Otherwise, if $b = 1$ it returns the real key K , else if $b = 0$ it returns a random key K' .

Without loss of generality, we assume that connected users in a session have the same password π from dictionary $\mathcal{D}$, and that the oracle chooses that same password upon initiation of a protocol instance Π_{ij} between two users $(\mathcal{U}_i, \mathcal{V}_j)$.

Freshness. An instance or user $\mathcal{U}_i$ is called **fresh**, if neither a **Reveal** query, nor a **Corrupt** query was placed by $\mathcal{A}$ upon it, or upon any other partnered user. Otherwise an instance is then called **unfresh**. This notion disallows $\mathcal{A}$ from winning the AKE security game trivially by testing sessions they previously revealed or corrupted their instances, and any instances partnered with them. The restriction made w.r.t. the **Corrupt** query allows for modeling (perfect) forward secrecy (PFS) and adaptive corruption.

BPR AKE Security. $\mathcal{A}$'s goal in the BPR security experiment is to distinguish between real and random session keys determined by the bit b for an accepting and fresh user.

Definition 19 (Security of Authenticated Key Exchange (AKE)). *For a protocol Π and an adversary $\mathcal{A}$, we define $\mathcal{A}$'s advantage with respect to Π as $\text{Adv}_{\mathcal{A}, \Pi}^{\text{BPR}}(1^\kappa)$. We say that the adversary wins if on issuing a **Test** query for a user $\mathcal{U}_i$ that has terminated in accepting state (i.e. is in possession of a session key K) and no **Reveal** or **Corrupt** query has been issued to this user, $\mathcal{A}$ correctly guesses the bit selected in the **Test** query. We say the protocol Π is secure if the probability of $\mathcal{A}$ winning is bounded to a negligible quantity:*

$$\text{Adv}_{\mathcal{A}, \Pi}^{\text{BPR}}(1^\kappa) \leq \frac{q_s}{|\mathcal{D}|} + \varepsilon(1^\kappa)$$

where q_s is the number of sessions $\mathcal{A}$ actively interacts with, $\mathcal{D}$ is a password dictionary and ε is a negligible function.

B Plain, Ring and Module LWE

A lattice is a discrete subgroup under addition of $(\mathbb{R}^n, +)$ and can be described as a set of points in n -dimensional space with a periodic structure. Formally, given n -linearly independent vectors $v_1, \dots, v_n \in \mathbb{R}^n$ the generated lattice is the set of vectors $L(v_1, \dots, v_n) := \{\sum_{i=1}^n \alpha_i v_i \mid \alpha_i \in \mathbb{Z}\}$ constructed by all possible integer linear combinations. The basis of a lattice L can also be denoted by a base matrix $\mathbf{A}$ representing its basis vectors. Lattices are of great interest to cryptographers since there are several classical computational problems in lattices from which cryptosystems can be built [65]. The most prominent are the Shortest Vector Problem (SVP), Closest Vector Problem (CVP), the Smallest Integer Solution

(SIS), and the Learning with Errors (LWE) problem. Nevertheless, public key cryptosystems from lattice problems are mostly based on worst-case reductions, making their choice of parameters stricter than average-case reductions [66]. Ultimately, even though lattices are defined in the Euclidean vector space $\mathbb{R}^n$, from a computational viewpoint, these problems are defined on integral lattices, whose representation is a matrix of integers. Hence, an irreducible polynomial f can replace a matrix base, and thus, a lattice can be defined as a special subset where all vectors form an ideal in a certain ring $\mathbb{Z}[x]/\langle f \rangle$. This led to extensive work on optimizing their key sizes in particular, and as a result several variations of lattice-based schemes dominated the NIST PQC process.

LWE. The decisional LWE problem [67] is basically to distinguish between (or find in the search variant) random linear equations from uniform equations after applying a small amount of noise. The Regev LWE-based public cryptosystem [68] is parametrized by a security parameter n , two integers (m, q) , and a probability distribution $\mathcal{X}$ over $\mathbb{Z}_q$. It defines the private key sk as a small vector $\mathbf{s} \in \mathbb{Z}_q^n$. The public key pk consists of LWE samples $(\mathbf{a}_i, b_i)_{i=1}^m$ from the LWE distribution such that $\mathbf{b} \equiv \mathbf{a}\mathbf{s} + \mathbf{e} \bmod q$ with the secret $\mathbf{s}$, modulus q and the small noise (error parameter) $\mathbf{e} \in \mathbb{Z}_q$. Without an error $\mathbf{e}$ finding a secret $\mathbf{s}$ would be easy using Gaussian elimination, hence the error, which according to Regev resembles the problem of decoding random linear codes [67], yet was proven secure through a reduction to the SVP problem in [68].

RLWE. In the ring variant (RLWE), the ring $R_q = \mathbb{Z}[x]/\langle x^n + 1 \rangle$ is defined as the ring of integer polynomials modulo $f(x)$ with n being a power of 2 and q a prime modulus so that $q \equiv 1 \bmod 2n$. Consequently, the elements of R_q are residues modulo both $f(x)$ and q . They can thus be viewed as integer polynomials of degree less than n with coefficients in a set of canonical representatives in $\mathbb{Z}_q$. An RLWE sample is chosen as $(\mathbf{a}, \mathbf{b})$ with $\mathbf{b} \equiv \mathbf{a}\mathbf{s} + \mathbf{e} \bmod q$ where $\mathbf{a} \in R_q$ is chosen uniformly, $\mathbf{s} \in R$ is a fixed secret chosen together with $\mathbf{e} \in R$ from an error distribution [67]. Hence, an RLWE sample $(\mathbf{a}, \mathbf{b}) \in R_q \times R_q$ can replace n standard LWE samples $(\mathbf{a}, \mathbf{b}) \in \mathbb{Z}_q^n \times \mathbb{Z}_q$, which reduces the size of the public key. The Lyubashevsky-Peikert-Regev RLWE cryptosystem [69] from ideal lattices encrypts a message $z \in \{0, 1\}^n$ by using its bits as $\{0, 1\}$ coefficients of a polynomial and choosing random elements $\mathbf{r}, \mathbf{e}_1, \mathbf{e}_2 \in R$ and outputting the encryption of z as a pair $(\mathbf{u}, \mathbf{v}) \in R_q^2$ where $\mathbf{u} = \mathbf{a}\mathbf{r} + \mathbf{e}_1 \bmod q$ and $\mathbf{v} = \mathbf{b}\mathbf{r} + \mathbf{e}_2 + \lfloor q/2 \rfloor \cdot z \bmod q$. The decryption computes $\mathbf{v} - (\mathbf{u} \cdot \mathbf{s}) = (\mathbf{r} \cdot \mathbf{e} - \mathbf{s} \cdot \mathbf{e}_1 + \mathbf{e}_2) + \lfloor q/2 \rfloor \cdot m \bmod q$. The coefficients of the small terms $(\mathbf{r} \cdot \mathbf{e} - \mathbf{s} \cdot \mathbf{e}_1 + \mathbf{e}_2)$ are in the range $-q/4, q/4$. Thus, a bit in z is then decrypted as 0 if $\mathbf{b} - \langle \mathbf{a}, \mathbf{s} \rangle$ is closer to 0 than to $\lfloor q/2 \rfloor \bmod q$, otherwise it is 1.

MLWE. The module (MLWE) variant was first defined by Brakerski et al. [70] and further studied by Langlois and Stehlé [71]. In essence, MLWE also replaces the integers in $\mathbb{Z}$ by a ring of algebraic integers R of a number field K . The new component here is $M \subseteq K^d$, a module of R . Therefore, the parameter n is introduced as the degree of the number field, and the integer d denotes the

module rank. With M being a rank d module and K of degree n , the resulting module lattice has the dimension $N = nd$. Hence, the MLWE problem generalizes both LWE and RLWE, as the RLWE variant is obtained if the module rank is $d = 1$. As a consequence, an MLWE sample is defined as $(\mathbf{a}, \mathbf{b})$ with $\mathbf{b} \equiv \mathbf{a}\mathbf{s} + \mathbf{e} \pmod{R}$ where $\mathbf{a} \in R_q^d$ is chosen uniformly, $\mathbf{s} \in R_q^d$ is a fixed secret, and $\mathbf{e}$ is sampled from an error distribution. The matrix representation for the lattice base is used when the number of samples m is fixed, which is denoted by $\mathbf{A} \in R_q^{m \times d}$.

C Further Lattice Assumptions

C.1 Extended Learning with Errors (eLWE).

The extended Learning with Errors assumption (eLWE) was first defined by O’Neill et al. in [57] in the context of proving security of deniable encryption from lattices (cf. Apon et al. [72]). eLWE has additionally been used by Alperin-Sheriff and Peikert [73] to show security theorems for circular and key-dependent message security of lattice identity-based encryption; and to show the classical hardness of LWE itself by Brakerski et al. [58]. The idea is to *extend* LWE security proofs like

$$(\mathbf{A}, \mathbf{A}\mathbf{s} + \mathbf{e}) \stackrel{\text{comp}}{\approx} (\mathbf{A}, \mathbf{u}),$$

to a setting with additional auxiliary information z ; i.e.,

$$(\mathbf{A}, \mathbf{A}\mathbf{s} + \mathbf{e}, z) \stackrel{\text{comp}}{\approx} (\mathbf{A}, \mathbf{u}, z).$$

In other words, eLWE claims that standard LWE computational hardness assumptions still hold, up to some very small concrete loss in bit-security — even in the presence of certain, additional (potentially non-uniform) “hints” z on the hidden terms $(\mathbf{s}, \mathbf{e})$ of an LWE equation. The typical form of such “eLWE leakage” z on the hidden values $(\mathbf{s}, \mathbf{e})$ takes the form of a chosen *inner product* $(\mathbf{z}, \langle \mathbf{z}, \mathbf{e} \rangle)$, where some vector $\mathbf{z}$ is *adversarially chosen* and $\langle \mathbf{z}, \mathbf{e} \rangle$ is the derived hint on honestly generated error $\mathbf{e}$. Intuitively, inner products reveal very little information on the LWE secret $(\mathbf{s}, \mathbf{e})$. Define the torus $\mathbb{T} = \mathbb{R}/\mathbb{Z}$, then we have:

Definition 20 (Extended (Plain) Learning with Errors (eLWE)). *For $n, m, q, t \geq 1$, $\mathcal{Z} \subseteq \mathbb{Z}^m$, and a distribution χ over $\frac{1}{q}\mathbb{Z}^m$, the $\text{eLWE}_{n,m,q,\chi,\mathcal{Z}}$ problem is as follows. The algorithm chooses $\mathbf{z} \in \mathcal{Z}$ and then receives the tuple*

$$(\mathbf{A}, \mathbf{b}, \langle \mathbf{e}, \mathbf{z} \rangle) \in \mathbb{T}_q^{n \times m} \times \mathbb{T}_q^m \times (1/q)\mathbb{Z}.$$

Its goal is to distinguish between two cases: First, $\mathbf{A} \in \mathbb{T}_q^{n \times m}$ is chosen uniformly, $\mathbf{e} \in (1/q)\mathbb{Z}^m$ is chosen from χ , and $\mathbf{b} = \mathbf{A}^T \mathbf{s} + \mathbf{e} \pmod{1}$ where $\mathbf{s} \in \{0, \dots, q-1\}^n$ are chosen uniformly. The second case is identical, except that $\mathbf{b}$ is chosen uniformly in $\mathbb{T}_q^m$ independently of everything else.

Prior works define a multi-hint version of eLWE, but we will only need the single-hint version as stated above. The hardness of eLWE follows from LWE, summarized as follows.

Theorem 7. For any $n \geq 2, q \geq 1, \varepsilon \in (0, 1/2)$, and $\alpha, r \geq (\frac{\ln(2m(1+1/\varepsilon))}{\pi})^{1/2}/q$, there is a reduction from $\text{LWE}_{n+1,m,q,\alpha}$ to $\text{eLWE}_{n,m,q,(\alpha^2\xi^2+r^2)^{1/2},\mathcal{Z}}$ that reduces the advantage by at most $33\varepsilon/2$, where ξ is a small constant factor.

Next, we make a simple observation, that Plain eLWE – originally designated to account for leakage on the error term e – also handles the case of leakage on the secret vector s in certain scenarios.

Definition 21 (Extended Learning With Errors (eLWE, alt version: secret leakage)). For $n, q, t \geq 1, \mathcal{Z} \subseteq \mathbb{Z}^n$, and a distribution χ over $\frac{1}{q}\mathbb{Z}^n$, the $\text{eLWE}_{n,q,\chi,\mathcal{Z}}$ problem is as follows. The algorithm gets to choose $\mathbf{z} \in \mathcal{Z}$ and then receives the tuple

$$(\mathbf{A}, \mathbf{b}, \langle \mathbf{s}, \mathbf{z} \rangle) \in \mathbb{T}_q^{n \times n} \times \mathbb{T}_q^n \times (1/q)\mathbb{Z}.$$

Its goal is to distinguish between two cases: First, $\mathbf{A} \in \mathbb{T}_q^{n \times n}$ is chosen uniformly (conditioned on being invertible), $\mathbf{s}, \mathbf{e} \in (1/q)\mathbb{Z}^n$ is chosen from χ , and $\mathbf{b} = \mathbf{A}\mathbf{s} + \mathbf{e} \bmod 1$. The second case is identical, except that $\mathbf{b}$ is chosen uniformly in $\mathbb{T}_q^n$ independently of everything else.

We claim that this version of eLWE (with leakage on the secret) asymptotically follows from standard eLWE (with leakage on the error) under the condition that $\mathbf{A}$ is invertible (modulo q), which requires $n = m$ in the previous statement of eLWE. In this case, $\mathbf{A}\mathbf{s} + \mathbf{e} = \mathbf{s} + \mathbf{A}^{-1}\mathbf{e}$ exactly, and the “alt” theorem follows by swapping the roles of $(\mathbf{A}, \mathbf{A}^{-1})$ and $(\mathbf{s}, \mathbf{e})$. The distinction between $\mathbf{s} \leftarrow U(\mathbb{Z}_q^n), \mathbf{e} \leftarrow \chi$ and $\mathbf{e}, \mathbf{s} \leftarrow \chi$ leads to at most a $(1/q)$ multiplicative loss in security (cf. [57]), which is clearly not tight. In instantiations from FrodoKEM, the proofs from the literature give a range of between $\ll 1$ and < 15 bits of security lost, and optimizing this concrete analysis is left to future work.

C.2 Non-uniform Module Learning with Errors (NMLWE)

For completeness, we define a module-lattice version of NLWE, adapted from Canetti and Chen [74, Lemma 2.13]

Definition 22 (Non-uniform Module Learning with Errors). Let $\lambda \in \mathbb{N}$ be the security parameter. Let $m, m, q, p \in \mathbb{N}, \sigma$ s.t. $0 < \sigma < q$. Let $R = \mathbb{Z}[X]/(X^n + 1)$ for n a power of 2, γ_σ be a distribution over $R^{m \times m}$ parameterized by σ , and χ_σ be distribution over R parameterized by σ , with $\|\gamma_\sigma\|, \|\chi_\sigma\| \leq \sigma\sqrt{m}$.

The NMLWE problem asks to distinguish between samples $(\mathbf{D}, \mathbf{K}\mathbf{D} + \mathbf{E}) \in (R^{m \times m} \times R^{1 \times m})$ from $(\gamma \times U(R_q^{1 \times m}))$, where $\mathbf{D} \leftarrow \gamma_\sigma$ is possibly non-uniform, $\mathbf{K} \leftarrow U(R_q^{1 \times m}), \mathbf{E} \leftarrow \chi_\sigma^{1 \times m}$.

We cite Canetti and Chen’s [74, Lemma 2.13] security claim for NMLWE.

Theorem 8. For $R = \mathbb{Z}[X]/(X^n + 1)$ where n is a power of 2, set parameters $m \geq 2n \log(q), \sigma = \omega(\sqrt{n \log(q)})$, and set discrete Gaussian distributions $\gamma_\sigma = D_{R^m, \sigma}^{1 \times m}, \chi_\sigma = D_{R, \sigma}$.

Then the hardness of NMLWE follows from the hardness of Plain LWE.

On the weakness of NMLWE security proofs. We remark that – to date – NMLWE has only been shown secure in contexts where one can choose a *high rank*; that is, $m \geq 2n \log(q)$. When the module-rank is appreciably lower than linear in the security parameter (especially in the case of Kyber, which uses rank 2, 3, or 4), known security reduction are vacuous.

To wit, we speculate that improving such security proofs to allow for arbitrarily small, constant rank would imply general-purpose program obfuscation $i\mathcal{O}$ for P/poly from standard lattice assumptions. We view this as negative evidence for obtaining such proof in the near term.

C.3 Extended Module Learning with Errors (eMLWE)

For completeness, following Alperin-Sheriff and Apon [75], we define a module-lattice version of eLWE as follows:

Definition 23 (Extended Module Learning with Errors (eMLWE)).

For security parameter $1^\kappa \in \mathbb{N}$, let $n = n(\lambda)$ be an integer dimension, let $f(x) = x^d + 1$ where $d = d(1^\kappa)$ is a power of 2, let $q = q(1^\kappa) > 2$ be an integer, let $R = \mathbb{Z}[x]/(f(x))$ and $R_q = R/qR$, and let $\chi = \chi(1^\kappa)$ be a distribution over R . Then, the $\text{eMLWE}_{n,d,f,q,\chi}$ problem is to distinguish between the following two distributions:

In the first distribution, one samples $(\mathbf{a}_i, b_i)$ uniformly from R_q^{n+1} . The adversary chooses $z_i \in R_q^n$ and then, for u_i uniformly from R_q^n , is presented with:

$$(\mathbf{a}_i, b_i)_i, (z_i)_i, \text{Tr}(\langle z_i, u_i \rangle)_i).$$

In the second distribution, one first draws $\mathbf{s} \leftarrow R_q^n$ uniformly, and samples $(\mathbf{a}_i, b_i) \in R_q^{n+1}$ by sampling $\mathbf{a}_i \leftarrow R_q^n$ uniformly, $e_i \leftarrow \chi$, and setting $b_i = \langle \mathbf{a}_i, \mathbf{s} \rangle + e_i$. The adversary chooses $z_i \in R_q^n$ and then is presented with:

$$(\mathbf{a}_i, b_i)_i, (z_i)_i, \text{Tr}(\langle z_i, \mathbf{s}_i \rangle)_i),$$

where the use of the trace function $\text{Tr}(\cdot)$ explicitly permits the adversary to request any $\mathbb{Q}$ -linear function of the secret vector, as viewed in the coefficient embedding, for its hints.

We cite Alperin-Sheriff and Apon’s [75, Lemma 3.3] security claim for eMLWE.

Theorem 9. *There is a reduction from $\text{LWE}_{d,w,q,\alpha}$ to either of:*

1. Following [73]: $\text{eMLWE}_{d,w,q,\alpha,k}$ that reduces the advantage by at most q^k , multiplicatively.
2. Following [58]: $\text{eMLWE}_{d+k,w,q,(\alpha^2+r^2)^{1/2},k}$, where $r \geq \omega(\sqrt{\log(w)})$, which reduces the advantage by at most a negligible amount, additively – given the change in dimension and error rate.

On the weakness of eMLWE security proofs. A key gap in the security offered by eMLWE is that it considers leakage of (potentially, traces of) inner products $\langle z_i, u_i \rangle$ over the various coordinates i of the vectors of polynomials in the problem statement. Fundamentally, there is no compression of dimension as in (Plain) eLWE, so an entire ring element leaks (compared to a single integer modulo q for Plain eLWE), which – to date – prevents many applications in entropic security arguments.